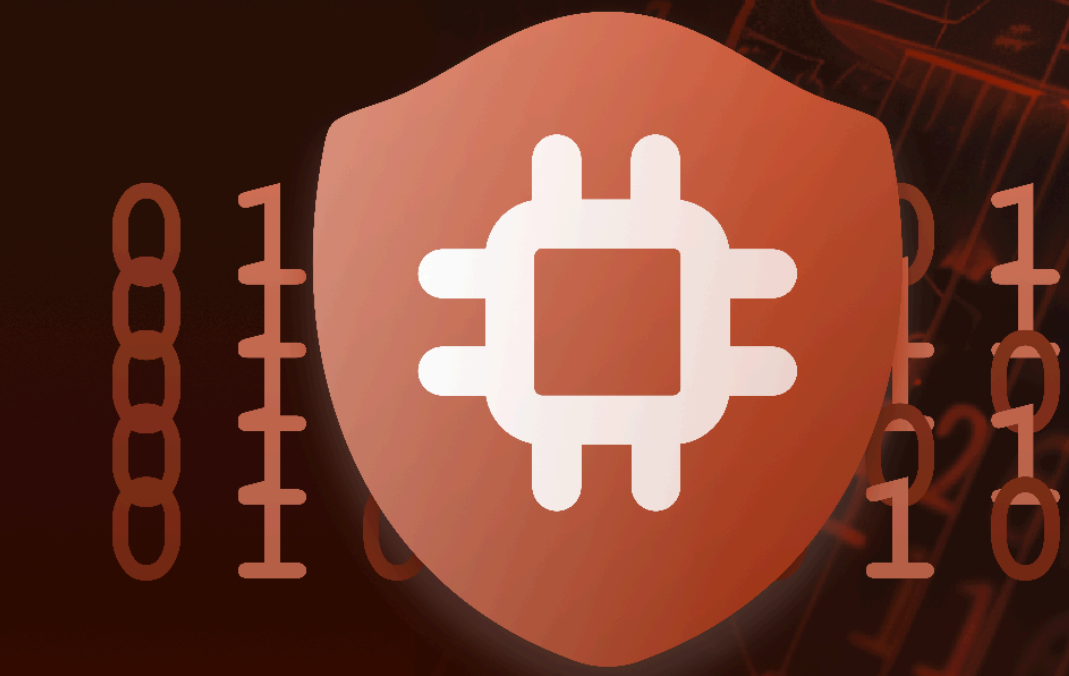
Information-Centric
Network Laboratory

FILKOM

Forge Day 2026 **Module**

Cyber Security



Daftar Isi

Daftar Isi **2**

1. Konsep Dasar Keamanan Siber **5**

1.1 Keamanan Siber 5

1.2 Tiga Pilar Keamanan Informasi 6

1.3 Ancaman, Kerentanan, dan Risiko 6

1.4 Red Team dan Blue Team 7

1.5 Belajar Keamanan lewat CTF 8

2. Web Exploitation **9**

2.1 Pengantar Web Exploitation 9

2.1.1 Etika dan Aturan Main 9

2.1.2 Apa Itu CTF 10

2.2 Dasar HTTP dan DevTools 10

2.2.1 Request dan Response 10

2.2.2 Cookie 12

2.2.3 Browser DevTools 13

2.3 Recon: Informasi yang Tidak Sengaja Terbuka 14

2.3.1 Konsep 14

2.3.2 Kenapa Bisa Terjadi 16

2.3.3 Cara Mencegah 16

Hands-On 1: Recon 17

Part 1: Intip Kode 17

Part 2: Robot Penjaga 18

Part 3: Kepala Surat 20

Cek Pemahaman 21

2.4 Client-Side Trust 21

2.4.1 Konsep 23

2.4.2 Kenapa Bisa Terjadi 24

2.4.3 Cara Mencegah 24

Hands-On 2: Client-Side Trust 25

Part 1: Diskon 100% 25

Part 2: Aku Admin 27

Part 3: Tombol Terkunci 28

Cek Pemahaman 30

2.5 SQL Injection 31

2.5.1 Konsep 32

2.5.2 Kenapa Bisa Terjadi 35

2.5.3 Cara Mencegah 35

Hands-On 3: SQL Injection....35
Part 1: Login Tanpa Password....36
Part 2: Cari Buku....38
Part 3: Pesan Error....40
Cek Pemahaman....41
2.6 IDOR (Insecure Direct Object Reference)....41
2.6.1 Konsep....42
2.6.2 Kenapa Bisa Terjadi....43
2.6.3 Cara Mencegah....44
Hands-On 4: IDOR....44
Part 1: Rapor Tetangga....44
Part 2: Pintu Belakang....45
Part 3: Nomor Acak?....47
Cek Pemahaman....48
3. Digital Forensics....49
3.1 Pengantar Digital Forensics....49
3.1.1 Prinsip Dasar....49
3.1.2 Digital Forensics dalam CTF....50
3.2 Mengenal Jejak pada File....50
3.2.1 File Signature....51
3.2.2 Metadata....51
Hands-On 5: Analisis Metadata....51
Soal: Aku ICN....52
Petunjuk (Hint)....52
Langkah Pengerjaan....52
Langkah 1: Mengamati Gambar....52
Langkah 2: Mengunggah File ke Aperi'Solve....53
Langkah 3: Membaca Hasil Exiftool....54
Langkah 4: Melacak Lokasi dari GPS....55
3.3 Network Forensics dan Wireshark....56
3.3.1 Konsep....56
3.3.2 Mengenal Wireshark....56
3.3.3 Kenapa Bisa Terjadi....57
3.3.4 Cara Mencegah....58
Hands-On 6: Network Forensics....58
Soal: Login Bocor....59
Instalasi Netcat di Windows....59
Petunjuk (Hint)....59
Langkah Pengerjaan....59
Langkah 1: Membuka File .pcap....59
Langkah 2: Menyaring Request Login....60

Langkah 3: Membaca Username dan Password..... 61
Hands-On 7: Investigasi Serangan SQL Injection..... 62
Soal: Perpustakaan ICN Lab Diserang..... 63
Petunjuk (Hint)..... 63
Langkah Pengerjaan..... 64
Langkah 1: Mencari Payload Login dan Mengenali Penyerang..... 64
Langkah 2: Menganalisis Login dengan Follow HTTP Stream..... 65
Langkah 3: Menelusuri Serangan Lanjutan dari Penyerang..... 66
Sampai di sini, ketujuh jawaban sudah ditemukan. Langkah berikutnya adalah mengirim jawaban ke server quiz..... 69
Langkah 4: Menjawab Pertanyaan di Server Quiz..... 69
Cek Pemahaman..... 70
4. Cryptography..... 72
4.1 Pengantar Cryptography..... 72
4.1.1 Etika dan Aturan Main..... 72
4.1.2 Encoding, Enkripsi, dan Hashing..... 73
4.1.3 Alat yang Dipakai: CyberChef..... 73
4.1.4 Pola Pikir Peserta..... 74
4.2 Cipher Klasik..... 75
4.2.1 Konsep..... 75
4.2.2 Kenapa Bisa Terjadi..... 76
4.2.3 Cara Mencegah..... 77
Hands-On 8: Cipher Klasik..... 77
Part 1: Salam dari Kaisar..... 77
Part 2: Kunci Kata..... 78
Cek Pemahaman..... 80
4.3 Hashing..... 80
4.3.1 Konsep..... 80
4.3.2 Hash Bisa Ditebak..... 81
4.3.3 Kenapa Bisa Terjadi..... 81
4.3.4 Cara Mencegah..... 82
Hands-On 9: Hashing..... 82
Part 1: Password Bocor..... 82
Cek Pemahaman..... 83
Lampiran..... 84
Cheat Sheet..... 84
Belajar Lanjutan..... 84
5. Reverse Engineering..... 84
5.1 Pengantar Reverse Engineering..... 85
5.1.1 Dari Kode Menjadi Program..... 85
5.1.2 Alat yang Dipakai: strings dan CyberChef..... 85

5.2 Rahasia di Dalam Program....86
5.2.1 Konsep....86
5.2.2 Kenapa Bisa Terjadi....86
5.2.3 Cara Mencegah....87
Hands-On 10: Reverse Engineering....87
Soal: Kunci Gerbang....87
Petunjuk (Hint)....87
Langkah Pengerjaan....88
Langkah 1: Mencari Teks dengan strings....88
Langkah 2: Mengenali Teks yang Disamarkan....89
Langkah 3: Membalik XOR di CyberChef....89
Langkah 4: Membuka Gerbang....90
Cek Pemahaman....90
6. Binary Exploitation....91
6.1 Pengantar Binary Exploitation....91
6.1.1 Memori dan Stack....91
6.1.2 Segmentation Fault....92
6.1.3 Alat yang Dipakai: netcat....92
6.2 Buffer Overflow....92
6.2.1 Konsep....93
6.2.2 Kenapa Bisa Terjadi....93
6.2.3 Cara Mencegah....93
Latihan Extra: Buffer Overflow....94
Soal: Buku Tamu ICN Lab....94
Petunjuk (Hint)....95
Langkah Pengerjaan....95
Langkah 1: Membaca Kode Sumber....95
Langkah 2: Mencoba Input Normal....96
Langkah 3: Meluberkan Buffer....96
Cek Pemahaman....97

1. Konsep Dasar Keamanan Siber

Setiap kali membuka soal, tanyakan: apa yang dipercaya aplikasi ini dariku, dan bisakah aku mengubahnya? Harga di keranjang belanja, peran pengguna, ID data yang diminta, dan teks yang ditampilkan ulang semuanya berasal dari input yang bisa jadi tidak diperiksa ulang oleh server. Di situlah kelemahan biasanya muncul.

1.1 Keamanan Siber

Keamanan siber adalah upaya menjaga sistem, jaringan, dan data dari akses, perubahan, atau perusakan oleh pihak yang tidak berhak. Cakupannya bukan hanya perangkat lunak. Konfigurasi yang keliru, kebiasaan pengguna, dan prosedur kerja yang longgar sama-sama bisa menjadi pintu masuk. Karena itu keamanan tidak pernah berupa satu alat yang dipasang sekali, melainkan lapisan-lapisan yang saling menutup kekurangan.

Satu hal yang membedakan cara berpikir orang keamanan dari pengembang biasa adalah arah pertanyaannya. Pengembang bertanya bagaimana supaya fitur ini berjalan. Orang keamanan bertanya bagaimana fitur ini bisa dipakai di luar maksud pembuatnya.

Setiap kali membuka soal, tanyakan: apa yang dipercaya aplikasi ini dariku, dan bisakah aku mengubahnya? Harga di keranjang belanja, peran pengguna, ID data yang diminta, dan teks yang ditampilkan ulang semuanya berasal dari input yang bisa jadi tidak diperiksa ulang oleh server. Di situlah kelemahan biasanya muncul.

1.2 Tiga Pilar Keamanan Informasi

Hampir semua pembahasan keamanan bermuara pada tiga sifat yang ingin dijaga. Ketiganya dikenal sebagai CIA Triad, singkatan dari Confidentiality, Integrity, dan Availability.

- Kerahasiaan (Confidentiality): Data hanya bisa dibaca oleh pihak yang berhak. Bocornya daftar nilai siswa ke publik adalah pelanggaran kerahasiaan.
- Keutuhan (Integrity): Data tidak berubah tanpa izin. Nilai ujian yang diam-diam diubah adalah pelanggaran keutuhan, walaupun tidak ada data yang bocor.
- Ketersediaan (Availability): Sistem bisa dipakai saat dibutuhkan. Situs pendaftaran yang lumpuh pada hari terakhir pendaftaran adalah pelanggaran ketersediaan.

Sebuah serangan bisa melanggar lebih dari satu pilar sekaligus. Pada soal-soal web di bab berikutnya, yang paling sering dilanggar adalah kerahasiaan dan keutuhan.

1.3 Ancaman, Kerentanan, dan Risiko

Tiga istilah ini sering dipakai bergantian dalam percakapan sehari-hari, padahal artinya berbeda dan urutannya penting.

- Kerentanan (vulnerability): Kelemahan yang ada pada sistem, misalnya form login yang menyisipkan input pengguna langsung ke dalam perintah database.

- Ancaman (threat): Pihak atau kejadian yang berpotensi memanfaatkan kelemahan tersebut, misalnya penyerang yang sedang mencari celah SQL Injection.
- Risiko (risk): Gabungan keduanya, yaitu seberapa besar kemungkinan ancaman berhasil memanfaatkan kerentanan dan seberapa besar dampaknya.

Kerentanan yang belum ditemukan siapa pun tetap berbahaya, karena ia hanya menunggu ancaman yang tepat. Sebaliknya, ancaman sebesar apa pun tidak berdampak jika tidak ada kerentanan yang bisa dimanfaatkan. Pekerjaan keamanan sehari-hari sebagian besar adalah mengurangi kerentanan, karena bagian itulah yang paling bisa dikendalikan.

1.4 Red Team dan Blue Team

Dalam praktiknya, pekerjaan keamanan dibagi ke dalam dua sudut pandang yang saling melengkapi.

- Red team: Berperan sebagai penyerang. Tugasnya mencari dan membuktikan kelemahan sebelum penyerang sungguhan menemukannya.
- Blue team: Berperan sebagai penjaga. Tugasnya memantau, mendeteksi, dan menutup kelemahan, termasuk menyelidiki kejadian yang sudah terlanjur terjadi.

Modul ini menyentuh keduanya. Kategori Web Exploitation, Cryptography, dan Binary Exploitation melatih cara berpikir red team, sedangkan Digital Forensics melatih cara berpikir blue team.

1.5 Belajar Keamanan lewat CTF

Keamanan sulit dipelajari hanya dengan membaca, karena yang perlu dilatih adalah kepekaan terhadap hal yang terlihat normal tetapi sebenarnya bisa disalahgunakan. Capture The Flag memberi lingkungan yang aman untuk melatih kepekaan itu, berupa sistem yang sengaja dibuat rentan, tujuan yang jelas berupa flag, dan jawaban yang bisa langsung diverifikasi.

Yang dilatih bukan menghafal payload, melainkan kebiasaan bertanya. Dari mana data ini datang? Siapa yang menentukan nilainya? Apa yang terjadi jika saya mengirim sesuatu yang tidak diduga pembuatnya? Kebiasaan inilah yang nanti terpakai ketika menjaga sistem sungguhan.

2. Web Exploitation

Hampir semua layanan yang kita pakai sehari-hari, mulai dari situs sekolah, toko online, sampai aplikasi perbankan, berjalan sebagai aplikasi web. Aplikasi web menawarkan kemudahan berupa fleksibilitas karena dapat diakses dari mana saja, banyaknya layanan yang berjalan sebagai aplikasi web menyebabkan maraknya serangan siber yang ditujukan ke layanan web. Pernahkah kamu bertanya-tanya bagaimana sebuah halaman login bisa ditembus, atau kenapa data milik orang lain kadang terbuka hanya dengan mengubah satu angka di alamat situs?

Modul ini membahas Web Exploitation, salah satu kategori dalam Capture The Flag (CTF). Kamu akan belajar mengenali kelemahan umum pada aplikasi web melalui tantangan yang dibuat khusus untuk latihan, lalu mempelajari cara memperbaikinya. Setiap bab terdiri dari materi singkat dan sesi Hands-On yang langkah-langkahnya bisa diikuti satu per satu.

2.1 Pengantar Web Exploitation

Web Exploitation adalah kategori CTF yang berfokus pada menemukan dan memanfaatkan kelemahan aplikasi web untuk mendapatkan flag. Tantangannya berupa situs latihan yang sengaja dibuat rentan, sehingga peserta bisa mencoba teknik serangan tanpa merugikan pihak lain. Tujuan akhirnya bukan sekadar menembus sebuah situs, tetapi memahami kenapa kelemahan itu terjadi dan bagaimana cara mencegahnya.

2.1.1 Etika dan Aturan Main

Bayangkan seorang siswa yang penasaran, lalu mencoba teknik dari video tutorial pada situs sekolahnya tanpa izin. Walau niatnya hanya coba-coba,

tindakan seperti itu bisa berurusan dengan hukum dan dengan pihak sekolah. Karena itu, pegang aturan berikut.

- Semua teknik di modul ini hanya boleh dipraktikkan di platform CTF kegiatan ini.
- Mengakses sistem elektronik milik orang lain tanpa izin dapat dipidana menurut hukum di Indonesia (aturan tentang akses ilegal, antara lain dalam UU ITE dan KUHP).
- Prinsipnya: boleh membongkar kunci, selama kunci tersebut memang disediakan untuk kebutuhan latihan.
- Jika menemukan celah di luar platform latihan, misalnya di aplikasi sekolah, jangan dieksploitasi. Laporkan ke guru atau pengelola sistem.

2.1.2 Apa Itu CTF

Capture The Flag (CTF) adalah kompetisi mencari flag, yaitu teks rahasia yang tersembunyi di dalam sebuah sistem. Setiap soal (challenge) berdiri sendiri, memiliki kategori dan tingkat kesulitan, dan flag yang ditemukan dikirim (submit) ke platform untuk mendapat poin. Pada modul ini, flag berformat ICN{teks_rahasia}.

2.2 Dasar HTTP dan DevTools

Sebelum mencari kelemahan, kita perlu memahami bagaimana browser dan server berkomunikasi. Hampir semua teknik pada modul ini bekerja dengan mengamati, lalu mengubah, data yang dikirim di antara keduanya.

2.2.1 Request dan Response

Setiap kali membuka halaman web, browser mengirim request ke server, lalu server membalas dengan response. Contoh sederhananya seperti berikut.

```
GET /login.php?user=admin HTTP/1.1
Host: situs-latihan.example
Cookie: session=abc123

HTTP/1.1 200 OK
Set-Cookie: role=user
Content-Type: text/html
```



Gambar 2.1 Alur request dan response antara browser dan server

- **Method:** GET meminta data, biasanya lewat URL. POST mengirim data, biasanya lewat form.
- **Status Code:** 200 (berhasil), 403 (dilarang), 404 (tidak ditemukan), 500 (error di server).
- **Header:** Informasi tambahan pada request dan response, misalnya Cookie dan Content-Type.

Dua method yang paling sering ditemui adalah GET dan POST, dan perbedaan keduanya penting saat kita mengamati maupun mengubah request.

GET dipakai untuk meminta data. Parameternya ikut tertulis di URL setelah tanda tanya, misalnya /cari?kata=buku. Karena berada di URL, parameter GET terlihat di address bar, tersimpan di riwayat browser, dan bisa diubah hanya dengan

mengetik ulang alamatnya. Itu sebabnya banyak soal recon dan IDOR cukup diselesaikan dari address bar.

POST dipakai untuk mengirim data, biasanya dari sebuah form. Parameternya diletakkan di body request, bukan di URL, sehingga tidak muncul di address bar. Tidak terlihat bukan berarti aman: isi body tetap bisa dilihat dan diubah lewat tab Network di DevTools atau lewat alat lain. Perbedaan keduanya hanya soal letak, bukan soal perlindungan.

Selain keduanya masih ada method lain seperti PUT dan DELETE yang biasa dipakai pada API, tetapi pada modul ini kita cukup berfokus pada GET dan POST.

2.2.2 Cookie

Cookie adalah data kecil yang disimpan browser dan dikirim kembali ke server pada setiap request. Server memakainya untuk mengingat pengguna antar request, misalnya status login. Karena disimpan di browser, isi cookie bisa dilihat dan diubah.

Alurnya seperti ini. Saat login berhasil, server mengirim header Set-Cookie yang berisi penanda sesi. Browser menyimpan penanda tersebut, lalu melampirkannya lewat header Cookie pada setiap request berikutnya ke situs yang sama. Dari sanalah server tahu bahwa request yang baru datang berasal dari orang yang tadi login, padahal HTTP sendiri tidak mengingat apa pun di antara request.

Ada dua cara umum menyimpan status di dalam cookie, dan keduanya berbeda jauh dari sisi keamanan. Cara pertama menyimpan nilainya secara langsung, misalnya role=user. Cara ini berbahaya, karena pengguna bisa mengubah nilainya sendiri lewat tab Application. Cara kedua menyimpan penanda acak

yang panjang, misalnya session=8f3a9c2d, lalu server yang menyimpan arti penanda tersebut. Pengguna tetap bisa mengubah penandanya, tetapi tebakan acak hampir pasti tidak cocok dengan data yang disimpan server.

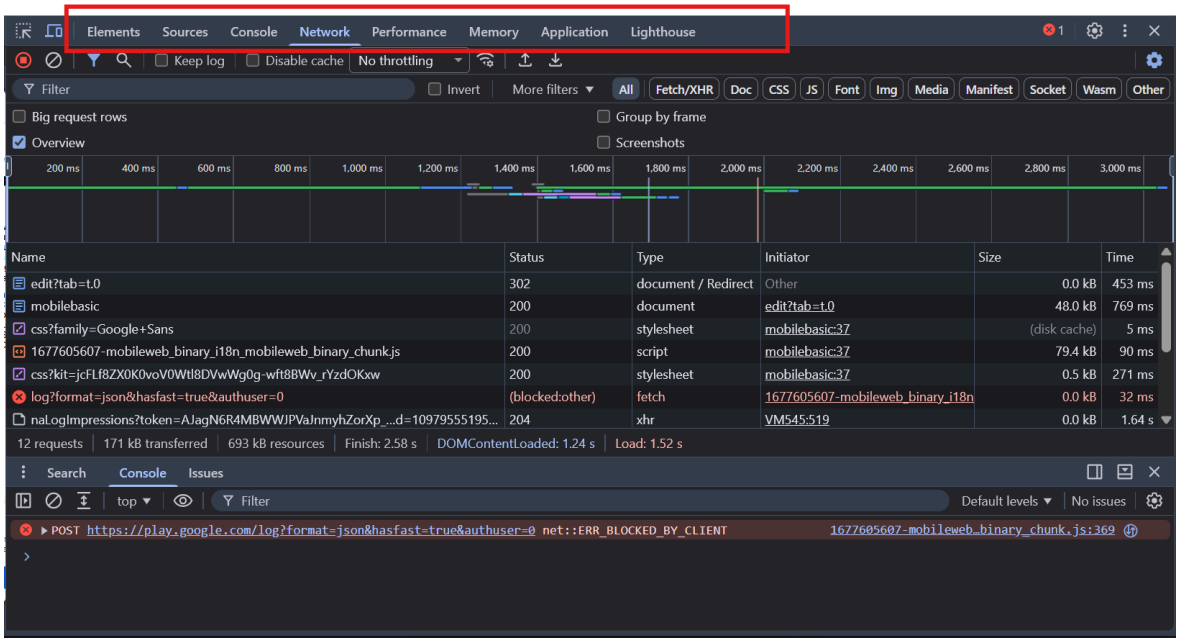
Beberapa atribut cookie yang akan kamu temui saat membuka tab Application:

- HttpOnly: Cookie tidak bisa dibaca lewat JavaScript, sehingga jauh lebih sulit dicuri.
- Secure: Cookie hanya dikirim lewat koneksi HTTPS.
- Expires atau Max-Age: Menentukan sampai kapan cookie disimpan browser. Tanpa keduanya, cookie hilang saat browser ditutup.

2.2.3 Browser DevTools

DevTools adalah fitur bawaan browser untuk memeriksa halaman web. Buka dengan menekan F12, atau klik kanan pada halaman lalu pilih Inspect. Bagian yang paling sering dipakai pada modul ini:

- **Elements:** Melihat dan mengedit HTML halaman, hanya sementara di browser kamu.
- **Console:** Menjalankan JavaScript dan melihat pesan error.
- **Network**: Melihat semua request yang dikirim halaman, termasuk yang tidak terlihat di layar.
- **Application:** Melihat dan mengedit cookie. Di Firefox, tab ini bernama Storage.



Gambar 2.2 Tampilan DevTools beserta tab-tab yang dipakai

2.3 Recon: Informasi yang Tidak Sengaja Terbuka

Bayangkan sebuah situs latihan sekolah yang lupa menghapus komentar <!-- password sementara: admin123 --> dari halaman login. Siapa pun bisa menemukannya lewat View Page Source, tanpa tools canggih. Yang diperlukan hanya tahu ke mana harus melihat.

2.3.1 Konsep

Semua yang dikirim ke browser bisa dibaca pengguna, termasuk yang disembunyikan lewat tampilan. Tempat yang sering menyimpan informasi tanpa disengaja:

- **HTML comment:** (<!-- ... -->) dan file JavaScript yang dimuat halaman.
- **robots.txt**: File yang memberi tahu mesin pencari halaman mana yang tidak boleh diindeks. Isinya sering tanpa sadar membocorkan path yang dirahasiakan.

- **Header respons HTTP:** Kadang berisi informasi versi server atau data lain.
- **Tab Network di DevTools**: Menampilkan request AJAX yang tidak muncul di tampilan halaman.

Tiga tempat terakhir pada daftar di atas paling sering muncul pada soal, jadi ada baiknya dibahas sedikit lebih jauh.

robots.txt adalah file teks biasa yang diletakkan di akar situs dan bisa dibuka siapa pun lewat alamat seperti situs-latihan.example/robots.txt. Isinya berupa aturan sederhana yang ditujukan kepada mesin pencari.

```
User-agent: *
Disallow: /admin/
Disallow: /backup-lama/
```

Baris Disallow berarti jangan indeks halaman ini, bukan jangan buka halaman ini. File tersebut sama sekali tidak mengunci apa pun. Mesin pencari yang patuh akan melewatinya, sedangkan manusia justru mendapat daftar lokasi yang menurut pemilik situs sebaiknya tidak ditemukan orang. Di situlah ironinya: upaya menyembunyikan halaman malah menghasilkan peta menuju halaman itu.

Tab Network di DevTools menampilkan setiap request yang dibuat halaman, bukan hanya alamat yang kamu ketik di address bar. Halaman modern sering mengambil data tambahan di belakang layar lewat AJAX, misalnya daftar produk atau isi profil, dan request semacam itu tidak terlihat pada tampilan halaman maupun pada View Page Source. Dengan membuka tab Network lalu memuat ulang halaman memakai F5, semua request tersebut muncul satu per satu. Mengklik salah satunya memperlihatkan alamat tujuan, method yang dipakai, header yang dikirim, dan balasan dari server. Endpoint yang tidak pernah disebut di menu navigasi sering ditemukan dari sini.

Header respons HTTP adalah keterangan tambahan yang dikirim server bersama halaman. Sebagian bersifat teknis dan wajar, seperti Content-Type yang memberi tahu jenis isi balasan. Sebagian lain membocorkan hal yang sebenarnya tidak perlu diketahui pengunjung, misalnya Server: Apache/2.4.49 yang menyebut perangkat lunak beserta nomor versinya, atau X-Powered-By yang menyebut bahasa pemrograman yang dipakai. Informasi versi seperti itu mempersingkat pekerjaan penyerang, karena ia tinggal mencari kelemahan yang sudah diketahui untuk versi tersebut. Pengembang juga kadang meninggalkan header buatan sendiri dari masa pengembangan, misalnya X-Debug-Token, lalu lupa menghapusnya saat rilis. Semua header respons bisa dilihat di tab Network, dengan mengklik salah satu request lalu membuka bagian Response Headers.

2.3.2 Kenapa Bisa Terjadi

```
<!-- index.php -->
<!-- TODO: hapus sebelum rilis. Backup admin: admin_backup2024 -->
<html>
  <body>...</body>
</html>
```

Developer menganggap apa yang dikirim ke browser tidak akan dilihat pengguna biasa. Padahal semua yang sampai ke browser sudah dapat diakses siapa pun yang membuka halaman itu.

2.3.3 Cara Mencegah

- Jangan menaruh data rahasia (password, kunci API, catatan internal) di HTML, JavaScript, atau header, karena semuanya terkirim ke client.
- Jangan mengandalkan menyembunyikan sesuatu sebagai proteksi. Menulis path rahasia di robots.txt justru membuatnya lebih mudah ditemukan.

- Bersihkan komentar developer dan header debug sebelum rilis ke produksi.

Hands-On 1: Recon

Pada sesi hands-on ini, peserta akan mencari flag yang tersembunyi di tempat-tempat yang jarang dilihat pengguna biasa: source halaman, file robots.txt, dan header respons HTTP.



Part 1: Intip Kode

Flag tersembunyi di komentar HTML pada halaman utama.

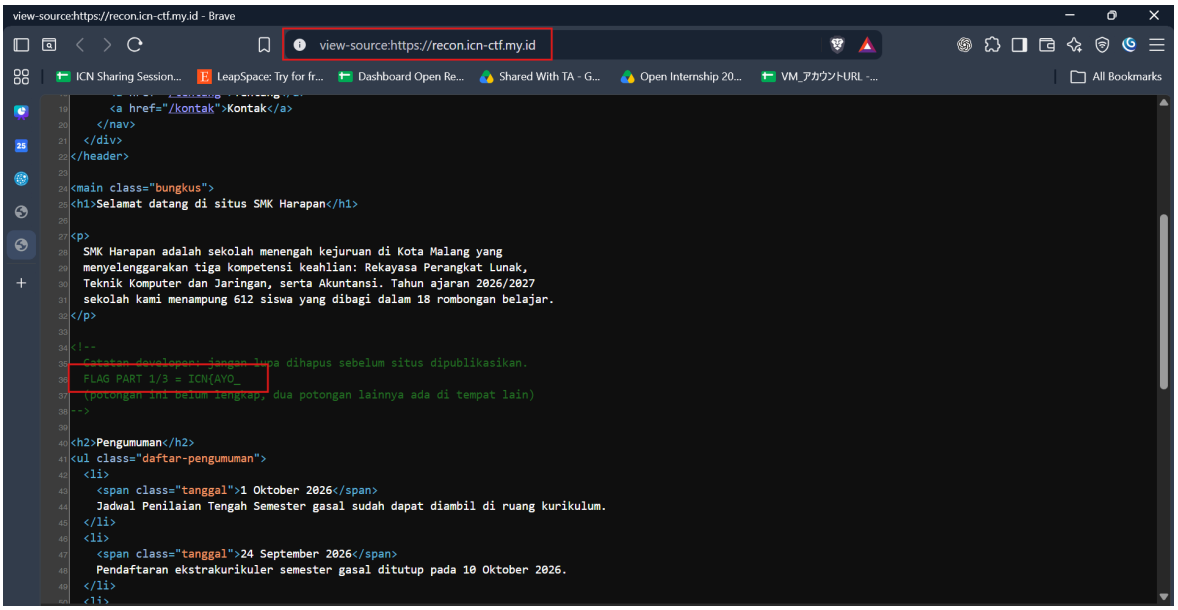
Petunjuk (hint):

- **Hint 1:** Coba klik kanan pada halaman dan lihat opsi yang tersedia.
- **Hint 2**: Shortcut Ctrl+U membuka source halaman langsung.

Langkah-langkah:

- Buka soal Intip Kode di platform, lalu buka halaman target.

- Tekan Ctrl+U untuk membuka source halaman (atau klik kanan lalu pilih View Page Source).
- Amati dan temukan bagian flag dengan format ICN{FLAG}



Gambar 2.3 Mencari flag di source halaman

FLAG PART 1/3 = ICN{AYO_

Part 2: Robot Penjaga

Ada halaman tersembunyi yang tidak boleh diindeks mesin pencari.

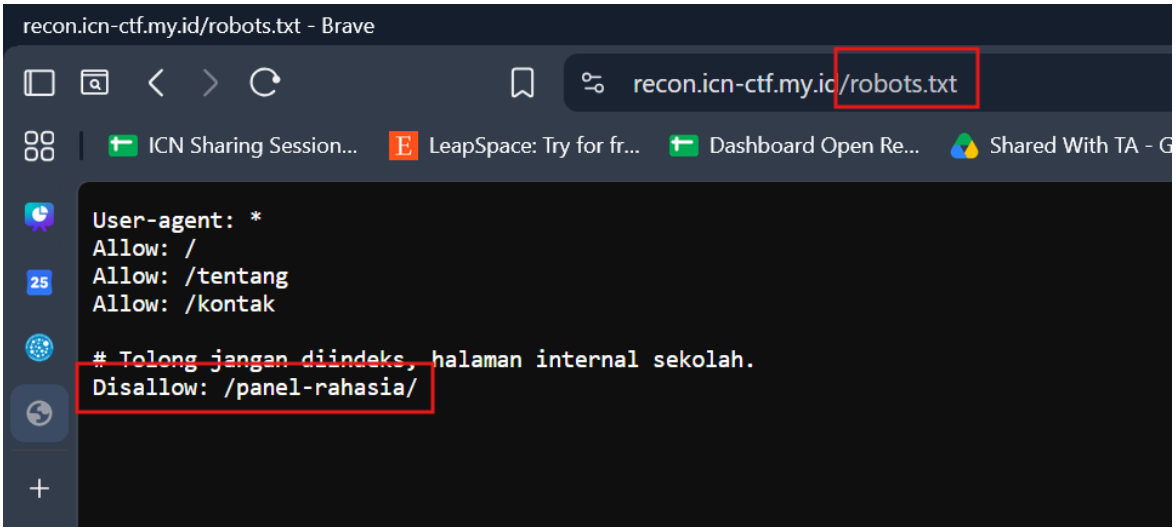
Petunjuk (hint):

- **Hint 1:** file apa yang biasa dibaca robot mesin pencari sebelum mengindeks sebuah situs?
- **Hint 2**: coba akses /robots.txt pada alamat situs.
- **Hint 3**: Baris Disallow: menunjuk ke path halaman tersembunyi itu.

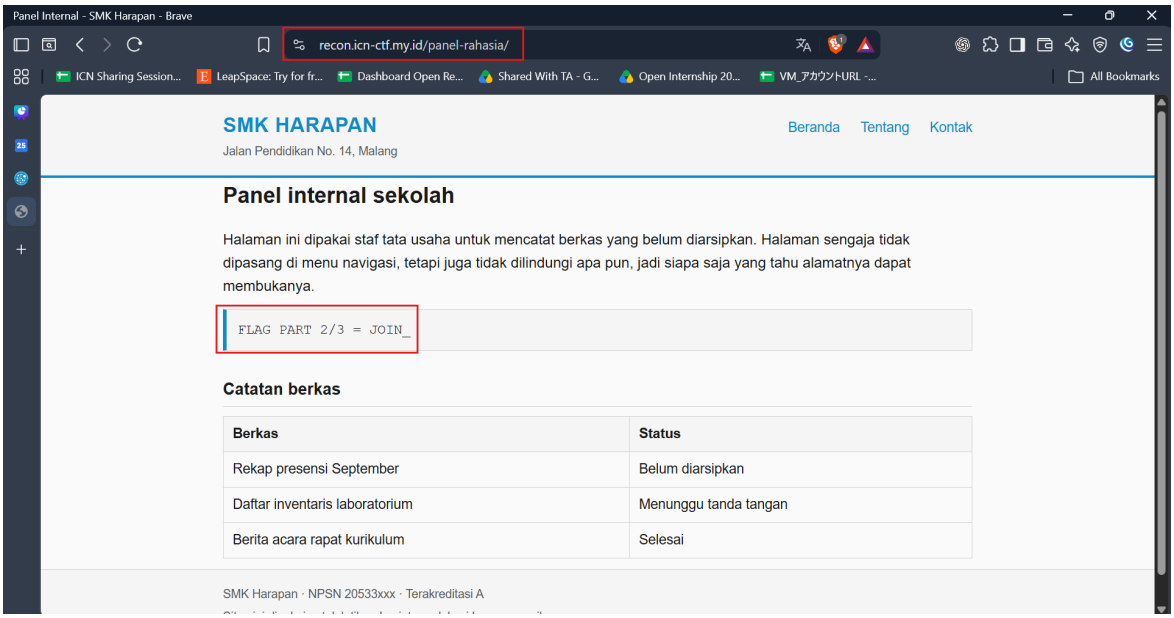
Langkah-langkah:

- Pada address bar, tambahkan /robots.txt di belakang alamat situs soal, lalu tekan Enter.

- Baca isi file. Catat path pada baris Disallow:, misalnya Disallow: /panel-rahasia/.
- Buka path tersebut di browser dengan menambahkannya di belakang alamat situs.
- Flag tampil di halaman itu. Salin dan submit di platform.



Gambar 2.4 Isi file robots.txt



Gambar 2.5 Halaman /panel-rahasia

FLAG PART 2/3 = JOIN_

Part 3: Kepala Surat

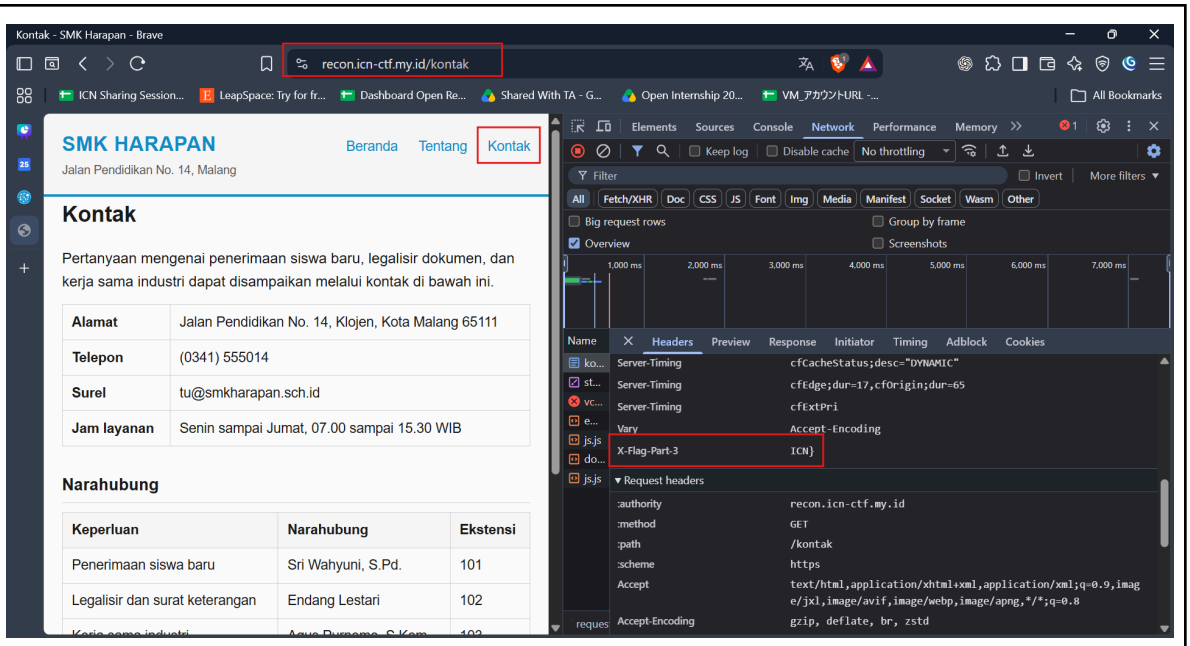
Flag ada di tempat yang bukan isi (body) halaman.

Petunjuk (hint):

- **Hint 1:** Selain body, respons HTTP juga punya bagian lain yang jarang dilihat orang.
- **Hint 2**: Buka tab Network di DevTools, klik request halaman, lalu lihat bagian Response Headers.
- **Hint 3**: cari header dengan nama yang tidak umum, bukan header standar seperti Content-Type.

Langkah-langkah:

- Buka halaman /kontak, lalu tekan F12 untuk membuka DevTools.
- Pilih tab Network, lalu muat ulang halaman dengan F5.
- Klik request pertama pada daftar (request untuk dokumen halaman).
- Pada panel yang terbuka, cari bagian Response Headers
- Temukan header yang tidak standar, misalnya yang berawalan X-. Nilainya adalah flag.



Gambar 2.6 Melihat Response Headers di tab Network

FLAG PART 3/3 = ICN}

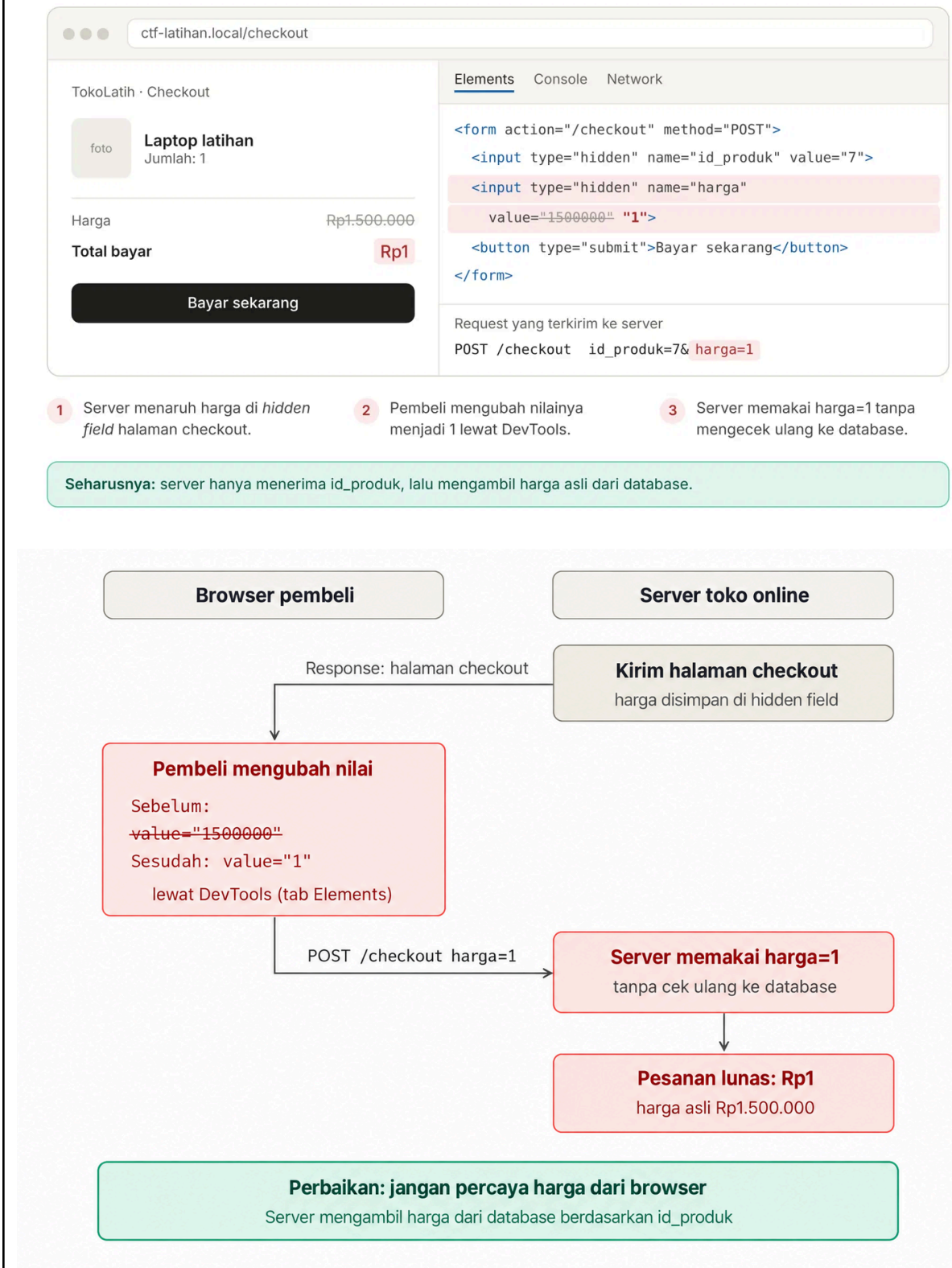
FLAG: ICN{AYO_JOIN_ICN}

Cek Pemahaman

1. Kenapa menyembunyikan URL admin lewat robots.txt tetap berbahaya walau tidak muncul di mesin pencari?
2. Selain HTML comment, sebutkan satu tempat lain yang sering menyimpan informasi tanpa disengaja.

2.4 Client-Side Trust

Bayangkan sebuah toko online latihan yang mengambil harga produk dari kolom tersembunyi di halaman checkout. Pembeli yang mengubah nilai kolom itu menjadi 1 sebelum menekan tombol Bayar bisa membeli barang dengan harga yang ia tentukan sendiri. Toko itu mempercayai harga yang dikirim balik oleh browser pembeli, bukan mengambilnya ulang dari database.



Gambar 2.7 Client-Side Trust

2.4.1 Konsep

Apa pun yang berjalan di browser pengguna, yaitu HTML, JavaScript, dan cookie, sepenuhnya berada di bawah kendali pengguna itu. Validasi yang hanya ada di sisi client mudah dilewati.

- **Hidden field**(<input type="hidden">) tetap bisa diedit lewat DevTools.
- **Validasi JavaScript** (maxlength, disabled fungsi pengecekan sebelum submit) hanya kosmetik, karena bisa dimatikan atau dilewati.
- **Cookie** yang menyimpan status seperti role=user bisa diubah menjadi role=admin lewat tab Application.

Akar masalahnya adalah soal batas kepercayaan. Semua yang berada di sisi browser, yaitu HTML, JavaScript, cookie, dan localStorage, tersimpan di komputer pengguna dan sepenuhnya bisa ia ubah. Semua yang berada di sisi server berada di luar jangkauannya. Garis pemisah antara keduanya disebut batas kepercayaan, dan aturannya sederhana: apa pun yang menyeberang dari sisi pengguna ke sisi server harus dianggap bisa dipalsukan.

Yang sering menyesatkan adalah anggapan bahwa pengguna pasti memakai browser. Padahal request HTTP hanyalah teks biasa yang bisa disusun sendiri, misalnya dengan curl dari terminal atau dengan alat seperti Burp Suite. Lewat cara itu, validasi JavaScript bukan dilewati, melainkan tidak pernah dijalankan sama sekali. Form yang membatasi panjang masukan dengan maxlength tidak ada artinya jika request-nya dikirim tanpa melalui form.

Lalu untuk apa validasi di sisi client dibuat? Jawabannya adalah kenyamanan, bukan keamanan. Validasi client memberi tahu pengguna lebih cepat bahwa format email salah tanpa perlu menunggu balasan server, dan mengurangi request yang sia-sia. Keduanya berguna, tetapi tidak satu pun bersifat

melindungi. Aturan praktisnya begini: validasi di client boleh ada, validasi di server wajib ada, dan validasi di server tidak boleh menganggap client sudah memeriksanya.

Hal yang sama berlaku untuk upaya menyembunyikan sesuatu lewat tampilan. Menghapus tombol dari menu, mengubah kolom menjadi type="hidden", atau menonaktifkan tombol dengan atribut disabled hanya mengubah apa yang terlihat. Endpoint yang dituju tombol itu tetap bisa dipanggil langsung. Menyembunyikan bukanlah bentuk perlindungan, dan prinsip ini akan muncul lagi pada bagian IDOR.

2.4.2 Kenapa Bisa Terjadi

```
<!-- checkout.html -->
<form method="POST" action="/beli">
  <input type="hidden" name="harga" value="150000">
  <button type="submit">Beli Sekarang</button>
</form>
// beli.php (TIDAK aman)
$harga = $_POST['harga']; // dipercaya mentah-mentah dari form
prosesPembayaran($harga);
```

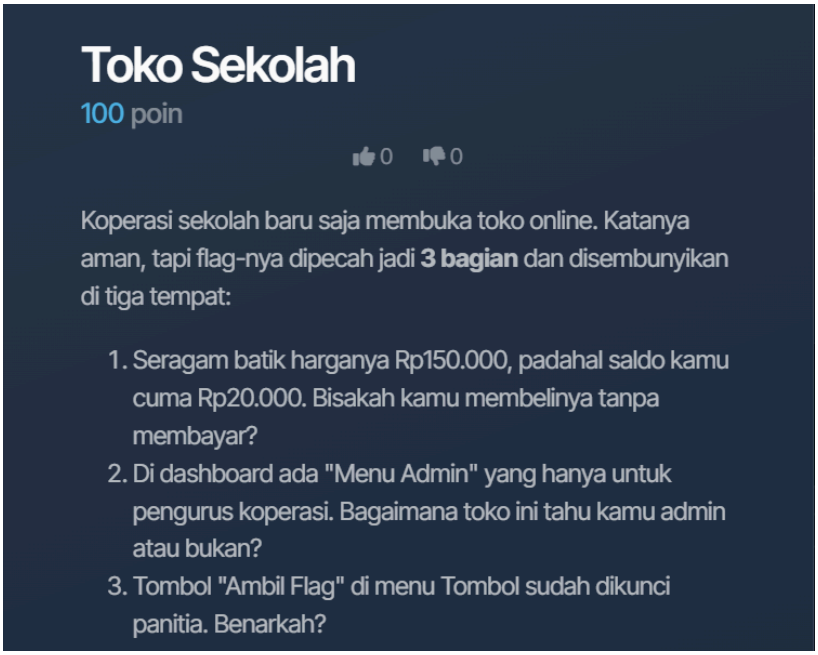
Server mengambil harga dari data yang dikirim form, bukan mengambil ulang dari database berdasarkan ID produk.

2.4.3 Cara Mencegah

- Validasi ulang semua data di server, termasuk harga. Ambil harga dari database berdasarkan ID produk, bukan dari input form.
- Simpan peran pengguna (role) di sesi server (session), bukan di cookie polos yang bisa dibaca dan diedit pengguna.
- Anggap validasi JavaScript hanya untuk kenyamanan pengguna, bukan untuk keamanan.

Hands-On 2: Client-Side Trust

Pada sesi hands-on ini, peserta akan mengubah data yang berada di sisi client, yaitu hidden field, cookie, dan atribut tombol, untuk melihat bahwa server yang tidak memeriksa ulang akan mempercayainya begitu saja.



Part 1: Diskon 100%

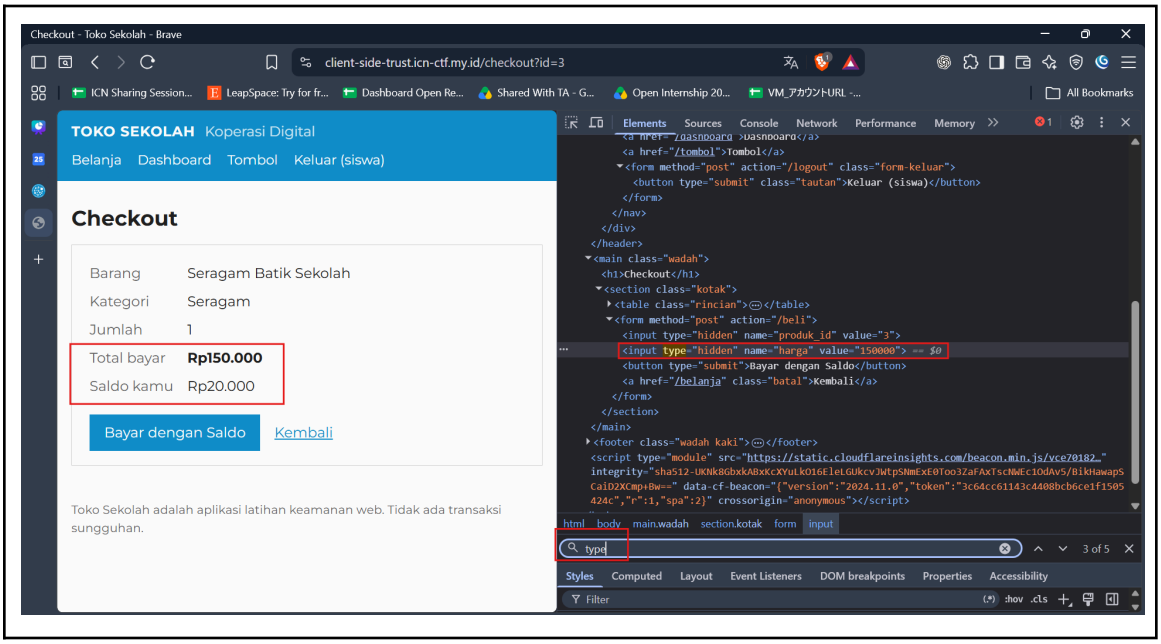
Ubah harga produk di keranjang belanja menjadi 0 sebelum checkout.

Petunjuk (hint):

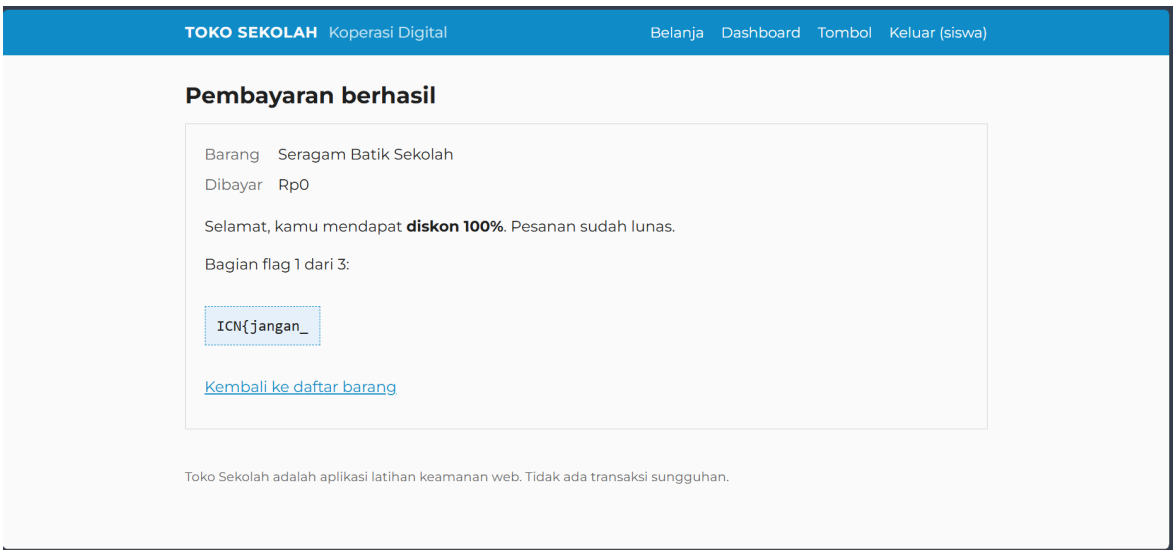
- **Hint 1:** Harga di halaman ini hanya ditampilkan, atau ikut dikirim balik ke server?.
- **Hint 2**: Buka tab Elements di DevTools, cari <input type="hidden"> bernama harga.
- **Hint 3**: Klik dua kali nilainya, untuk mengedit langsung di DevTools, lalu submit form.

Langkah-langkah:

- Login dengan username **siswa** dan password **siswa123**.
- Buka menu Belanja, lalu klik Beli pada Seragam Batik Sekolah (Rp150.000).
- Tekan F12 untuk membuka DevTools, lalu pilih tab Elements.
- Tekan Ctrl+F di panel Elements, lalu cari dengan menggunakan keyword “type” kemudian cari type=”hidden”.
- Temukan input bernama harga, misalnya value=”150000”.
- Klik dua kali nilai pada value, ganti menjadi 0, lalu tekan Enter.



- Klik tombol “Bayar dengan Saldo”, dan pembayaran akan dinyatakan berhasil.



Gambar 2.1 Mencari flag dengan mengubah value dari client-side

`FLAG PART 1/3 = ICN{jangan_`

Part 2: Aku Admin

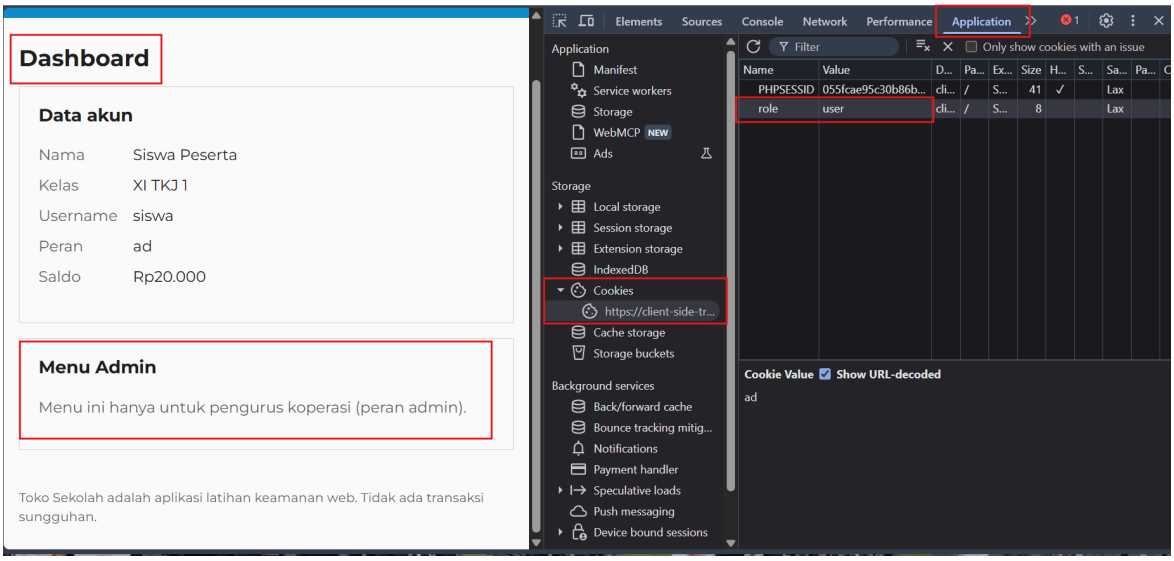
Dashboard hanya menampilkan menu admin jika sebuah cookie bernilai tertentu

Petunjuk (hint):

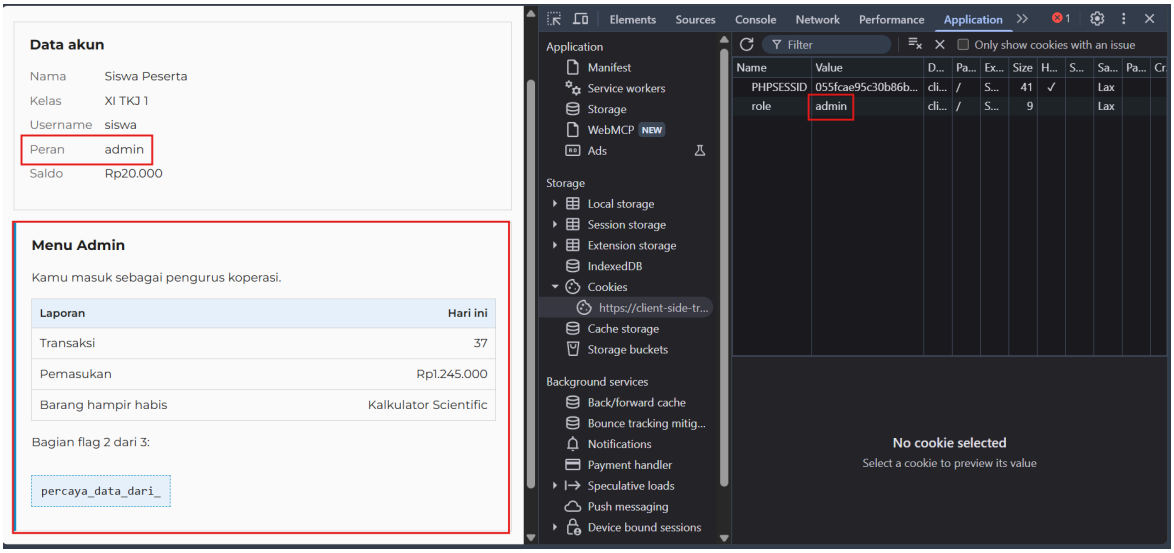
- **Hint 1:** Buka tab Application, lalu lihat nama-nama cookie yang tersimpan.
- **Hint 2**: Ada cookie bernama role dengan nilai user.
- **Hint 3**: Ubah nilainya menjadi admin lalu muat ulang halaman.

Langkah-langkah:

- Buka halaman dashboard
- Tekan F12, lalu pilih tab Application.
- Pada menu di sisi kiri, buka Cookies, lalu klik alamat situs soal.
- Cari cookie bernama role dengan nilai user.
- Klik dua kali kolom Value, ganti menjadi admin, lalu tekan Enter.
- Muat ulang halaman dengan F5. Menu admin dan flag muncul.



Gambar 1.4 Isi file robots.txt



Gambar 1.4 Isi file robots.txt

`FLAG PART 2/3 = percaya_data_dari`

Part 3: Tombol Terkunci

Tombol ambil flag abu-abu dan tidak bisa diklik.

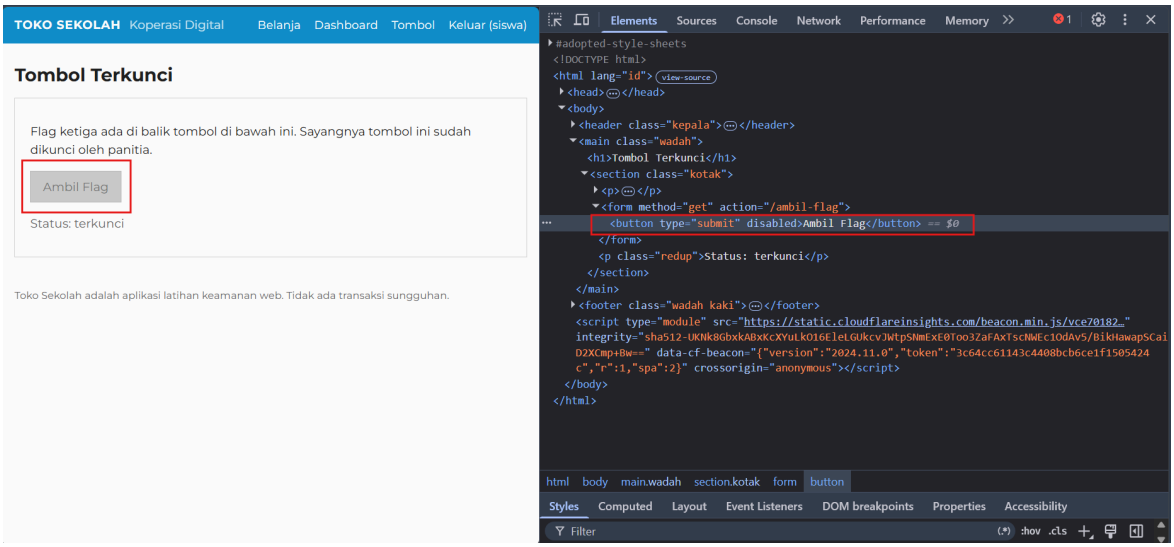
Petunjuk (hint):

- **Hint 1:** Tombol yang tidak bisa diklik biasanya punya satu atribut HTML tertentu.

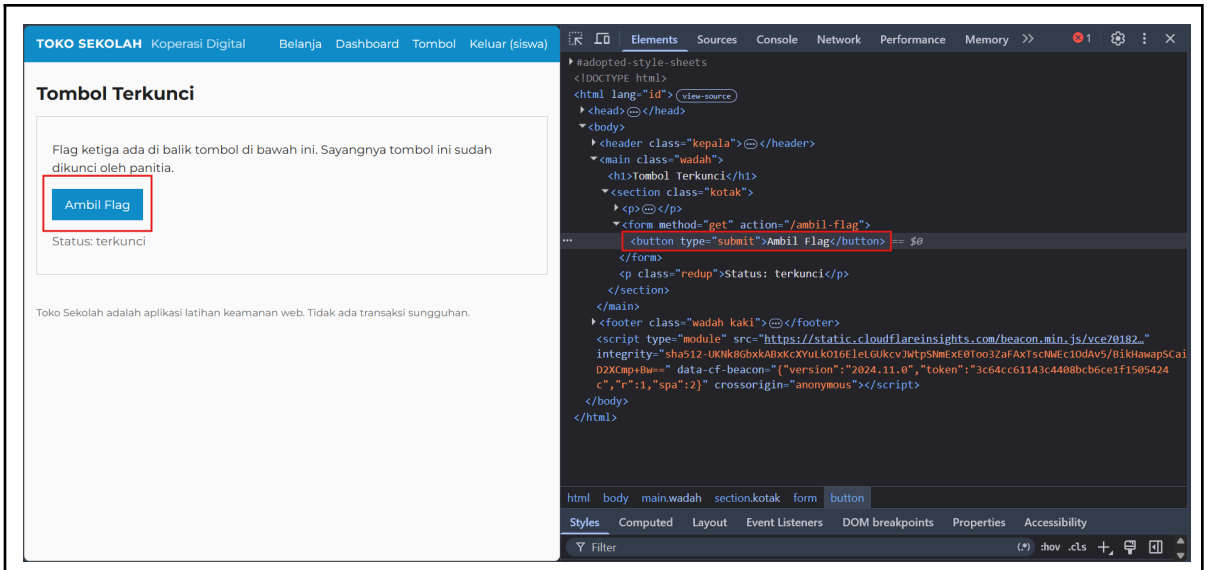
- **Hint 2**: Cari atribut disabled pada elemen tombol lewat DevTools.
- **Hint 3**: Hapus atribut itu langsung di panel Elements, lalu klik tombolnya.

Langkah-langkah:

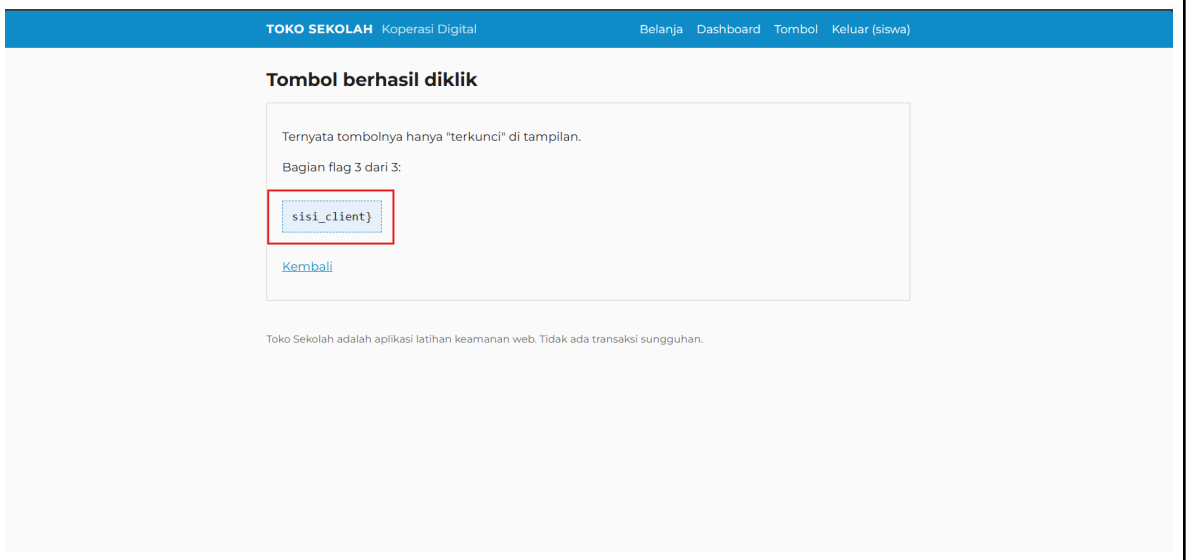
- Buka halaman soal dan perhatikan tombol Ambil Flag yang tidak bisa diklik.
- Klik kanan pada tombol, lalu pilih Inspect.
- Pada panel Elements, cari atribut disabled di elemen tombol.
- Klik kanan pada atribut tersebut lalu pilih Delete attribute (atau klik dua kali lalu hapus).
- Klik tombol Ambil Flag.



Gambar 1.6 Melihat Response Headers di tab Network



Gambar 1.6 Melihat Response Headers di tab Network



Gambar 1.6 Melihat Response Headers di tab Network

FLAG PART 3/3 = sisi_client}

FLAG: ICN{AYO_JOIN_ICN}

Cek Pemahaman

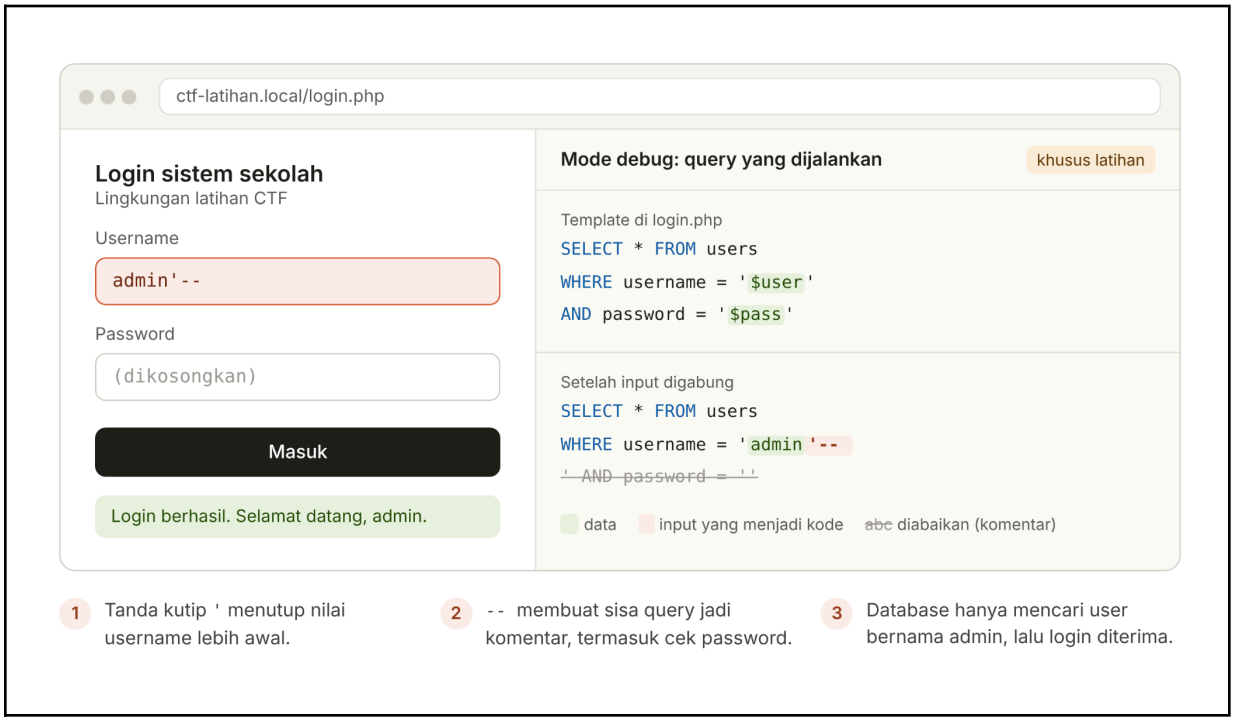
1. Kenapa validasi harga di JavaScript saja tidak cukup untuk mencegah kecurangan harga?
2. Sebutkan satu tempat penyimpanan sisi client yang bisa diedit langsung oleh pengguna lewat DevTools.

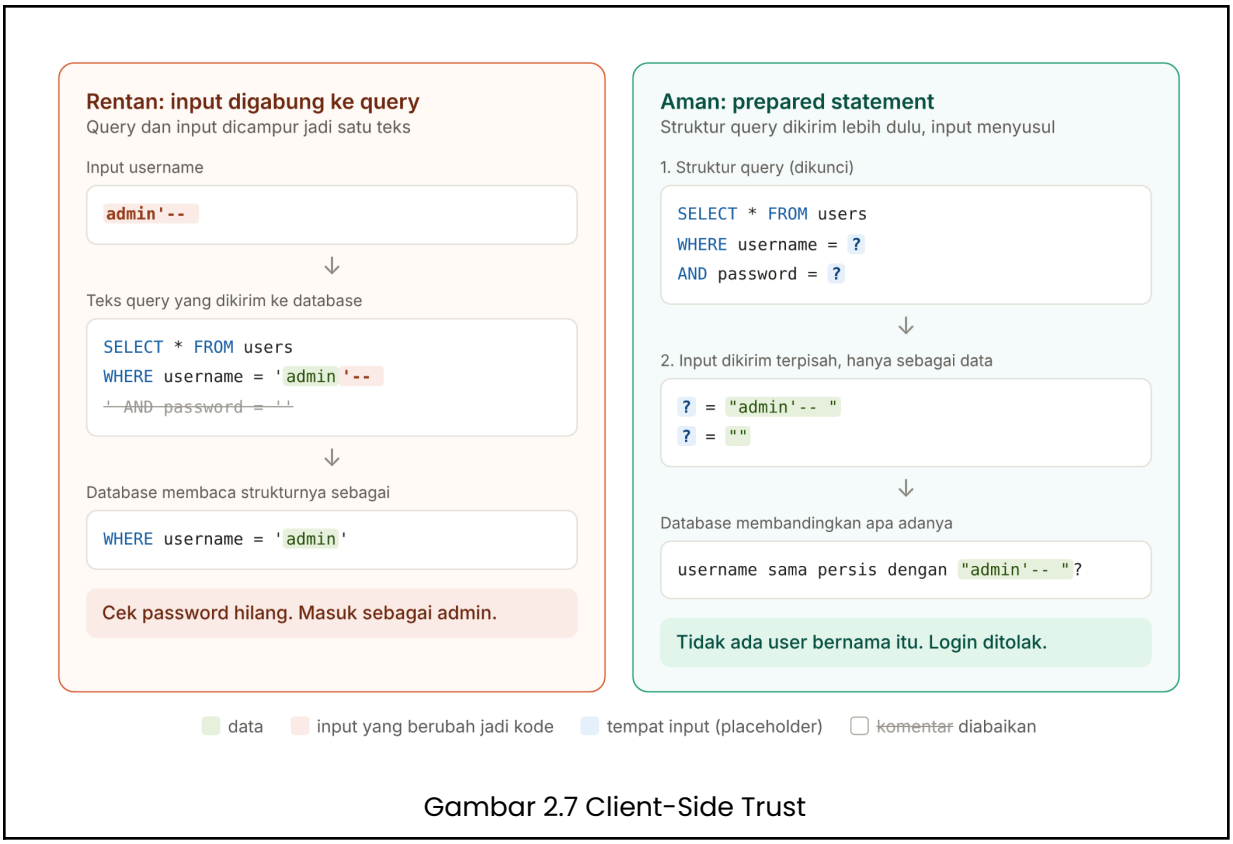
2.5 SQL Injection

Komik xkcd berjudul Exploits of a Mom menceritakan sebuah sekolah yang kehilangan seluruh data siswanya hanya karena satu nama.

```
Robert'); DROP TABLE Students;--
```

Nama itu tidak menghapus apa pun dengan sendirinya. Sistem sekolahlah yang menyisipkannya langsung ke dalam perintah database, sehingga sebagian nama ikut dibaca sebagai perintah, bukan sebagai teks biasa, lalu menghapus tabel data siswa. Komiknya fiksi, tetapi masalahnya nyata: jika input pengguna disisipkan langsung ke dalam perintah database, pengguna bisa mengubah arti perintah itu





Gambar 2.7 Client-Side Trust

2.5.1 Konsep

Database dikendalikan lewat bahasa SQL. Query login biasanya terlihat seperti ini:

```
SELECT * FROM users WHERE username = 'budi' AND password = 'rahasia123'
```

Jika nilai `budi` dan `rahasia123` datang langsung dari input form tanpa disaring, lalu disisipkan dengan cara digabung sebagai teks biasa, pengguna bisa memasukkan tanda kutip (') untuk keluar dari nilai yang dimaksud dan menulis instruksi SQL sendiri. Simbol `--` (dengan spasi di belakangnya) atau # membuat sisa baris query dianggap komentar dan diabaikan database.

Supaya lebih mudah mengikuti soal-soalnya, ada baiknya mengenali dulu bentuk dasar perintah SQL. Sebuah query untuk mengambil data umumnya

tersusun dari tiga bagian, yaitu data apa yang diambil, dari tabel mana, dan dengan syarat apa.

```
SELECT nama, kelas FROM siswa WHERE kelas = '12 RPL'
```

Bagian WHERE inilah yang paling sering menjadi pintu masuk, karena di situlah input pengguna biasanya ditempelkan. Ketika input pengguna digabung menjadi teks query, database tidak punya cara membedakan mana bagian yang ditulis pengembang dan mana yang berasal dari pengguna. Keduanya sudah menyatu menjadi satu kalimat perintah sebelum database membacanya.

Dari situ muncul tiga pola yang dipakai pada Hands-On 3. Pola pertama mengubah syarat agar selalu bernilai benar, sehingga pengecekan password menjadi tidak berarti. Pola kedua menyambung query asli dengan query tambahan memakai UNION SELECT untuk menarik data dari tabel lain. Pola ketiga sengaja membuat query menjadi salah supaya pesan error dari database membocorkan nama tabel atau kolom.

Tabel berikut merangkum bagian SQL yang dipakai pada materi dan soal di modul ini.

Bagian	Fungsi	Contoh pemakaian
`SELECT`	Menentukan kolom yang ingin diambil	`SELECT username, password`
`FROM`	Menentukan tabel sumber datanya	`FROM users`
`WHERE`	Memberi syarat supaya hanya baris tertentu yang diambil	`WHERE username = 'budi'`
`AND`	Menyambung dua	`WHERE username = 'budi' AND password`

	syarat, keduanya harus benar	`= 'rahasia'`
`OR`	Menyambung dua syarat, cukup salah satu yang benar	`WHERE username = 'budi' OR 1=1`
`'` (tanda kutip)	Penanda awal dan akhir sebuah teks di dalam query. Menyisipkannya membuat penyerang bisa keluar dari nilai lalu menulis perintah sendiri	`admin'`
`--` (dua tanda minus)	Menandai sisa baris sebagai komentar sehingga diabaikan database. Dipakai untuk membuang pengecekan password	`admin'--`
`ORDER BY`	Mengurutkan hasil berdasarkan kolom ke-n. Dipakai untuk menghitung jumlah kolom tabel sampai muncul error	`' ORDER BY 3--`
`UNION SELECT`	Menyambung hasil query lain ke hasil query asli. Jumlah kolomnya harus sama	`' UNION SELECT username, password, 3 FROM users--`
`DROP TABLE`	Menghapus seluruh tabel beserta isinya. Inilah perintah yang ada pada komik xkcd di awal bab	`DROP TABLE students`

2.5.2 Kenapa Bisa Terjadi

```
// login.php (TIDAK aman)
$user = $_POST['username'];
$pass = $_POST['password'];
$query = "SELECT * FROM users WHERE username = '$user' AND password =
'$pass'";
$result = mysqli_query($koneksi, $query);
```

Jika username diisi `admin'--` (spasi setelah dua tanda minus), query yang benar-benar dijalankan server menjadi:

```
SELECT * FROM users WHERE username = 'admin'-- ' AND password = ''
```

Bagian setelah `--` dianggap komentar, sehingga pengecekan password diabaikan. Login berhasil sebagai admin tanpa perlu tahu passwordnya.

2.5.3 Cara Mencegah

Gunakan prepared statement. Input pengguna dikirim terpisah dari struktur query, sehingga tidak bisa mengubah arti query.

```
// login.php (versi aman dengan PDO)
$stmt = $pdo->prepare("SELECT * FROM users WHERE username = ? AND password
= ?");
stmt->execute([$user, $pass]);
```

- Matikan `display_errors` di server produksi supaya pesan error database tidak bocor ke pengguna.
- Jangan menggabungkan input pengguna langsung ke string query, walau sudah difilter sebagian.

Hands-On 3: SQL Injection

Pada sesi hands-on ini, peserta akan menyisipkan input khusus ke form login dan kolom pencarian untuk mengubah query yang dijalankan database. Soal pertama menampilkan query yang dijalankan di bawah form, sehingga kamu bisa melihat sendiri bagaimana inputmu mengubahnya.



Part 1: Login Tanpa Password

Masuk sebagai admin tanpa tahu passwordnya.

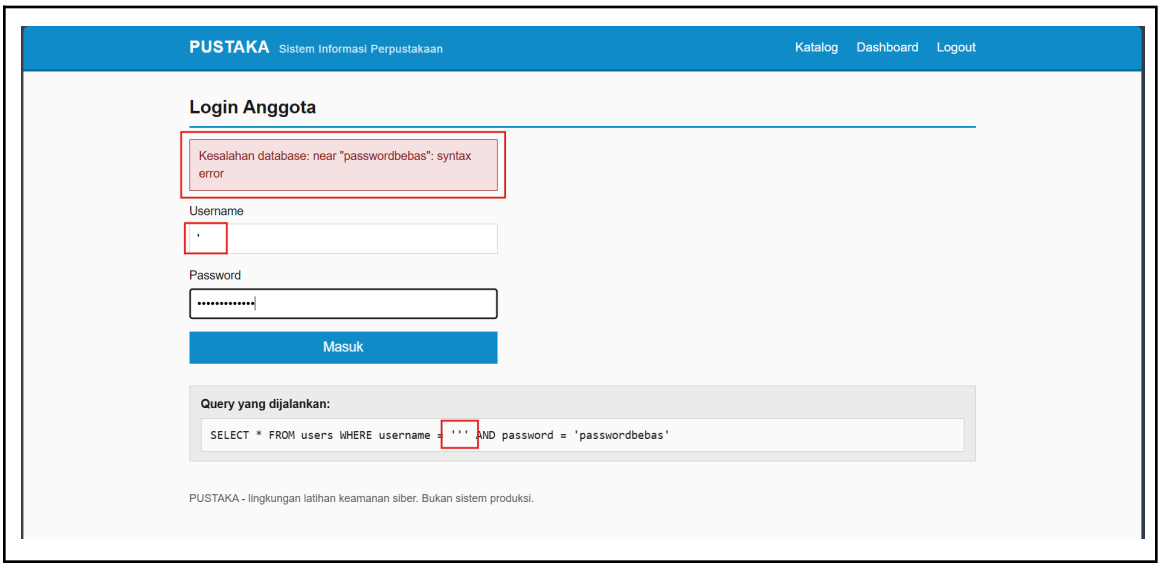
Petunjuk (hint):

- **Hint 1:** Coba masukkan satu tanda kutip tunggal (') di kolom username, lalu lihat apa yang terjadi.
- **Hint 2**: Tanda kutip bisa merusak struktur query. Sekarang buat sisa query setelah usernamemu diabaikan.
- **Hint 3**: Coba isi username dengan admin'--.. Kolom password boleh dikosongkan.

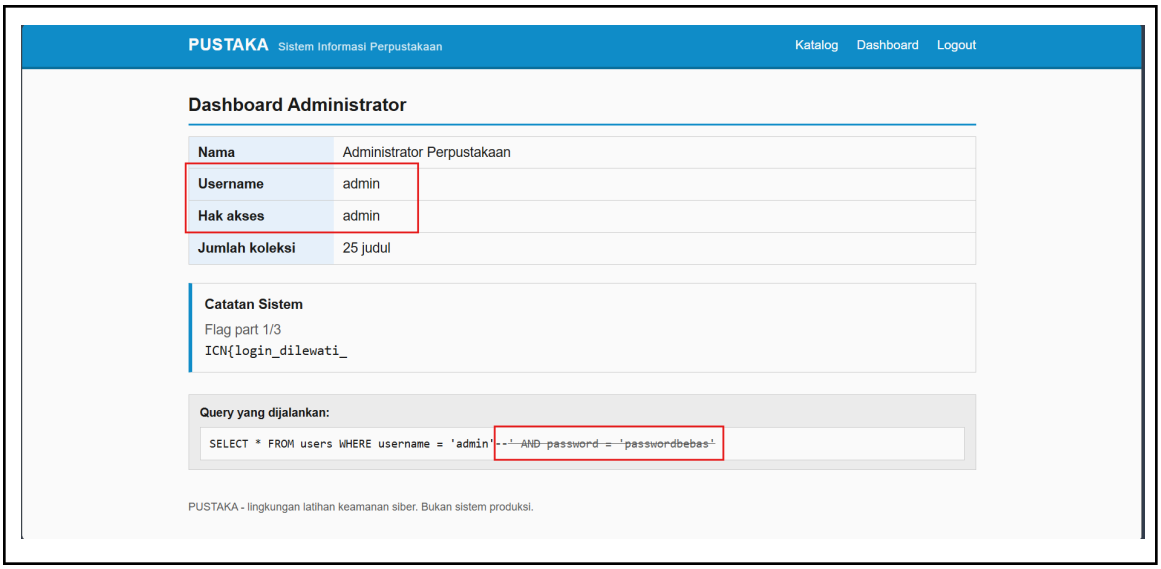
Langkah-langkah:

- Buka soal dan halaman form login.

- Isi username dengan satu tanda kutip ' dan password dengan teks bebas, lalu klik Login. Perhatikan perubahan pada query yang tampil atau pesan error yang muncul.



- Sekarang isi username dengan `admin'--` dan isi password dengan karakter apapun.
- Klik Login. Perhatikan query yang tampil: bagian setelah -- menjadi komentar, jadi pengecekan password diabaikan.
- Login berhasil sebagai admin. Flag ada di dashboard admin.



FLAG PART 1/3 = ICN{login_dilewati

Part 2: Cari Buku

Fitur pencarian buku rentan. Flag ada di tabel users, bukan di tabel buku.

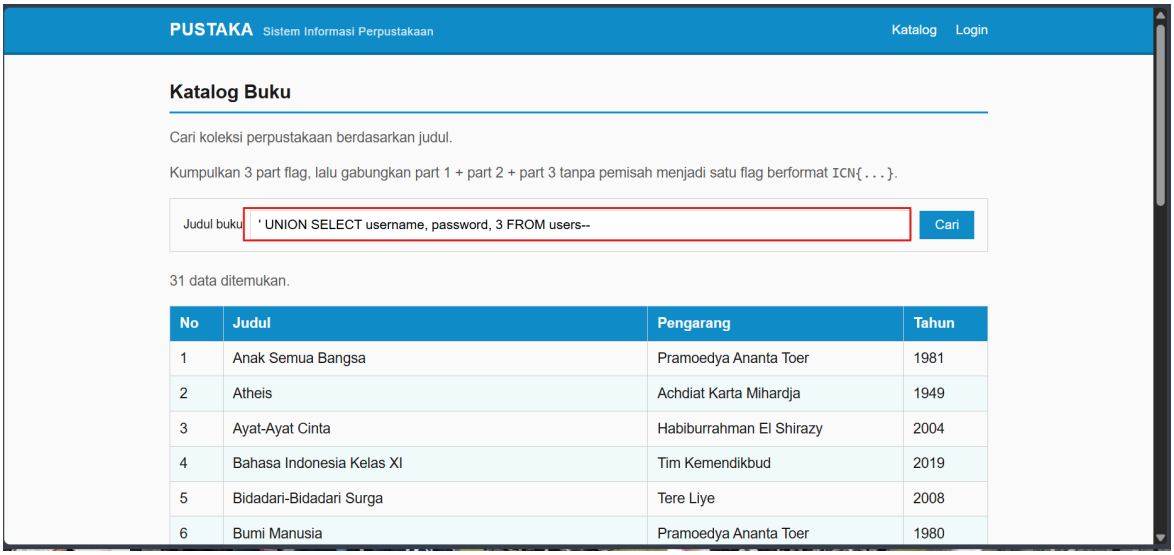
Petunjuk (hint):

- **Hint 1:** Ketik tanda kutip di kolom pencarian. Apakah muncul pesan error?
- **Hint 2**: Teknik `UNION SELECT` bisa menggabungkan hasil dari tabel lain ke hasil pencarian, asalkan jumlah kolomnya sama.
- **Hint 3**: Cari tahu jumlah kolom tabel buku dengan `' ORDER BY 1--` , `' ORDER BY 2--` , dan seterusnya sampai error. Setelah itu susun `UNION SELECT` dengan jumlah kolom yang sama, mengambil data dari tabel `users`.

Langkah-langkah:

- Buka soal dan coba fitur pencarian dengan kata biasa, misalnya judul buku.
- Ketik satu tanda kutip ' di kolom pencarian. Jika muncul error atau hasil berubah, kolom ini rentan.

- Cari jumlah kolom: kirim `' ORDER BY 1-- , lalu ' ORDER BY 2--` , dan seterusnya sampai muncul error.
- Jumlah kolom adalah angka terakhir sebelum error. Misalnya error muncul pada `ORDER BY 4`, berarti ada 3 kolom.
- Kirim `' UNION SELECT username, password, 3 FROM users--` (sesuaikan jumlah kolom dengan hasil langkah sebelumnya).
- Hasil pencarian menampilkan data akun. Flag ada di salah satu kolom password.



Gambar x.x Isi file robots.txt

17	Pemrograman Dasar untuk SMK	Rudi Hartono	2020
18	Perahu Kertas	Dee Lestari	2009
19	Pulang	Leila S. Chudori	2012
20	Ronggeng Dukuh Paruk	Ahmad Tohari	1982
21	Rumah Kaca	Pramoedya Ananta Toer	1988
22	Salah Asuhan	Abdoel Moeis	1928
23	Sang Pemimpi	Andrea Hirata	2006
24	Siti Nurbaya	Marah Rusli	1922
25	Supernova: Ksatria, Puteri, dan Bintang Jatuh	Dee Lestari	2001
26	admin	admin123	3
27	budi	budi2024	3
28	dewi	dewi2024	3
29	pustakawan	pakai_union_select_	3
30	sari	sari2024	3
31	siswa	siswa123	3

PUSTAKA - lingkungan latihan keamanan siber. Bukan sistem produksi.

Gambar x.x Isi file robots.txt

FLAG PART 2/3 = pakai_union_select_

Part 3: Pesan Error

Server menampilkan pesan error database secara lengkap.

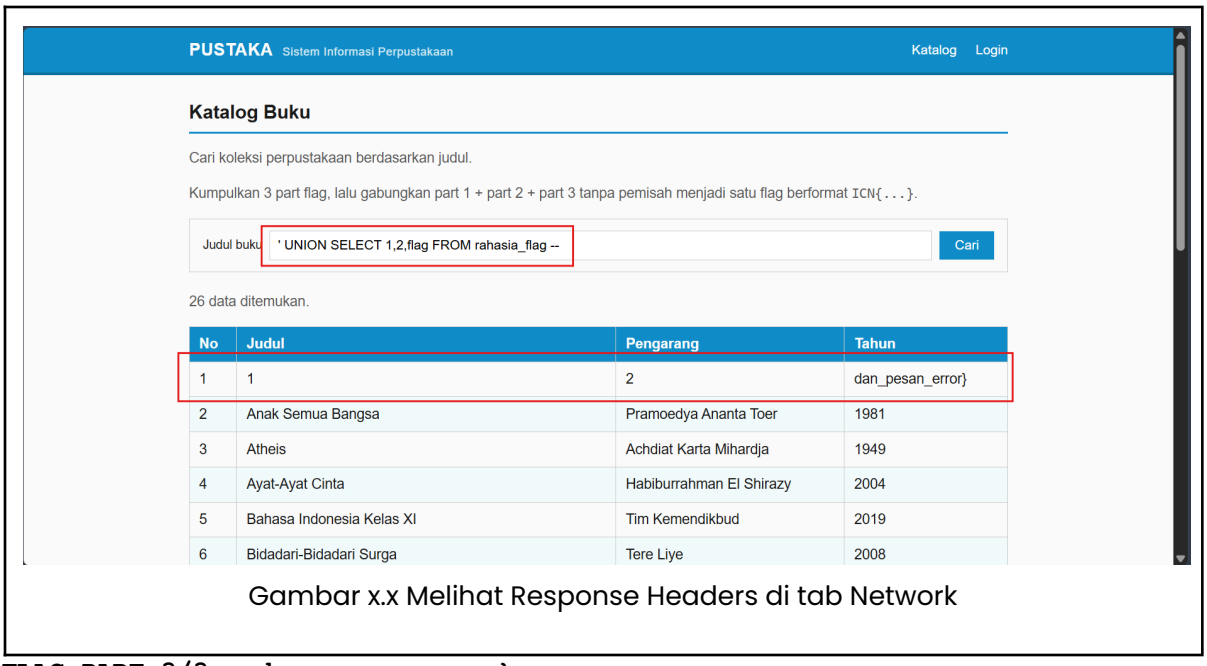
Petunjuk (hint):

- **Hint 1:** Kirim input yang sengaja membuat query salah sintaks, misalnya satu tanda kutip.
- **Hint 2**: Baca pesan error yang muncul. Pesan itu bisa membocorkan nama tabel atau kolom.
- **Hint 3**: Gunakan informasi dari pesan error untuk menyusun query lanjutan yang menampilkan isi tabel.

Langkah-langkah:

- Kirim satu tanda kutip ' pada kolom pencarian.
- Baca pesan error yang muncul, lalu catat nama tabel atau kolom yang disebut.

- Gunakan nama tersebut untuk menyusun `UNION SELECT` yang mengambil isi tabel itu, seperti pada Soal 2.
- Flag tampil pada hasil pencarian.



Gambar x.x Melihat Response Headers di tab Network

FLAG PART 3/3 = dan_pesan_error}

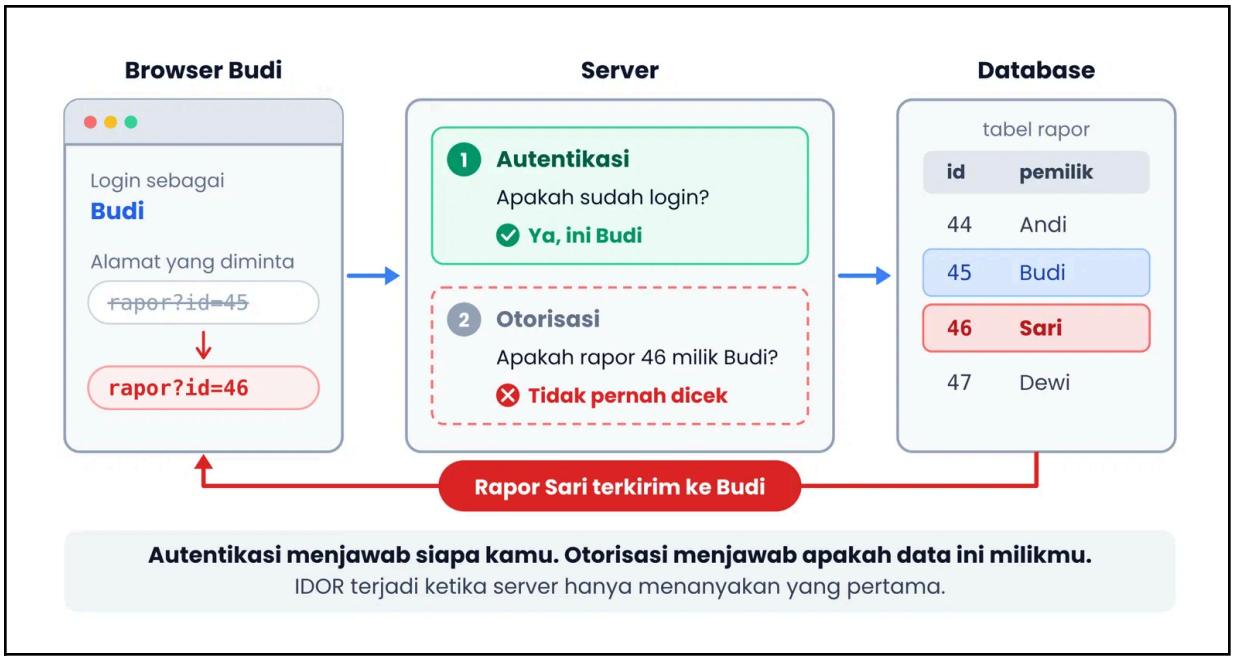
FLAG: ICN{login_dilewati_pakai_union_select_dan_pesan_error}

Cek Pemahaman

1. Kenapa payload `admin'--` bisa membuat pengecekan password diabaikan sepenuhnya?
2. Apa fungsi prepared statement dibanding menggabung string biasa untuk mencegah SQL Injection?

2.6 IDOR (Insecure Direct Object Reference)

Bayangkan seorang siswa membuka rapornya sendiri di `situs-sekolah.example/rapor?id=45`. Karena penasaran, ia mengubah angka 45 menjadi 46, dan rapor temannya ikut terbuka. Tidak ada trik rumit, hanya satu angka yang diganti di URL.



2.6.1 Konsep

- **Autentikasi:** Membuktikan siapa kamu (login berhasil).
- **Otorisasi** Memastikan kamu boleh mengakses data tertentu.

IDOR terjadi ketika aplikasi sudah benar soal autentikasi (kamu memang login), tetapi lupa memeriksa otorisasi (apakah data yang diminta memang milikmu). Jika ID data mudah ditebak, misalnya angka urut, dan kepemilikannya tidak dicek, siapa pun yang login bisa mengakses data orang lain.

Nama IDOR sendiri sudah menjelaskan masalahnya. Direct object reference berarti aplikasi menunjuk sebuah data memakai pengenal yang langsung menggambarkan letak data itu di penyimpanan, misalnya nomor baris pada tabel database. Pengenal semacam itu muncul apa adanya di URL, di kolom form, atau di isi request. Disebut insecure ketika aplikasi memakai pengenal kiriman pengguna untuk mengambil data, tanpa lebih dulu memeriksa apakah pengguna tersebut memang berhak atas data itu.

Ada dua arah penyalahgunaan yang perlu dibedakan. Arah mendatar adalah mengakses data milik pengguna lain yang setingkat, misalnya siswa membuka rapor siswa lain. Arah menegak adalah mengakses sesuatu yang seharusnya hanya untuk tingkat yang lebih tinggi, misalnya siswa membuka halaman yang disediakan untuk admin. Keduanya berakar pada kesalahan yang sama, yaitu pengecekan hak akses yang tidak dilakukan di server.

Pengenalnya juga tidak selalu berupa angka urut di URL. Hal yang sama bisa terjadi pada nama file di parameter unduhan, pada nomor pesanan di kolom tersembunyi sebuah form, pada ID di dalam isi request JSON, dan pada potongan alamat API seperti /api/user/45/profil. Karena itu saat mengerjakan soal, periksa semua tempat yang memuat pengenal, bukan hanya address bar.

Satu hal yang sering disalahpahami adalah peran pengenal yang sulit ditebak. Mengganti angka urut dengan UUID atau menyandikannya dengan base64 memang membuat tebakan lebih sulit, tetapi tidak menghilangkan kelemahannya. Base64 bukan penyandian rahasia dan bisa dibaca siapa pun dalam sekejap, seperti yang akan dicoba pada Part 3. UUID pun tetap bisa bocor lewat tautan yang dibagikan, lewat riwayat browser, atau lewat halaman lain di aplikasi yang sama. Pengenal yang sulit ditebak hanyalah lapisan tambahan, sedangkan pengamannya tetap satu, yaitu server memeriksa kepemilikan data pada setiap permintaan.

2.6.2 Kenapa Bisa Terjadi

```
// rapor.php (TIDAK aman)
session_start();
$id = $_GET['id'];
$rapor = queryDatabase("SELECT * FROM rapor WHERE id = $id");
tampilkan($rapor);
```

```
// tidak ada pengecekan apakah $id ini milik $_SESSION['user_id']
```

Server hanya mengecek apakah pengguna sudah login, bukan apakah data yang diminta memang miliknya.

2.6.3 Cara Mencegah

- Selalu cek kepemilikan data di server, misalnya `if ($rapor['user_id'] != $_SESSION['user_id']) { tolak(); }`.
- Cek peran pengguna di setiap endpoint sensitif, bukan hanya menyembunyikan link-nya dari menu.
- Gunakan ID yang sulit ditebak (misalnya UUID) sebagai lapisan tambahan. Ini pelengkap, bukan pengganti pengecekan otorisasi.

Hands-On 4: IDOR

Pada sesi hands-on ini, peserta akan mengganti nilai ID pada URL untuk membuka data yang bukan milik akun sendiri, lalu mengamati kenapa server mengizinkannya.

Part 1: Rapor Tetangga

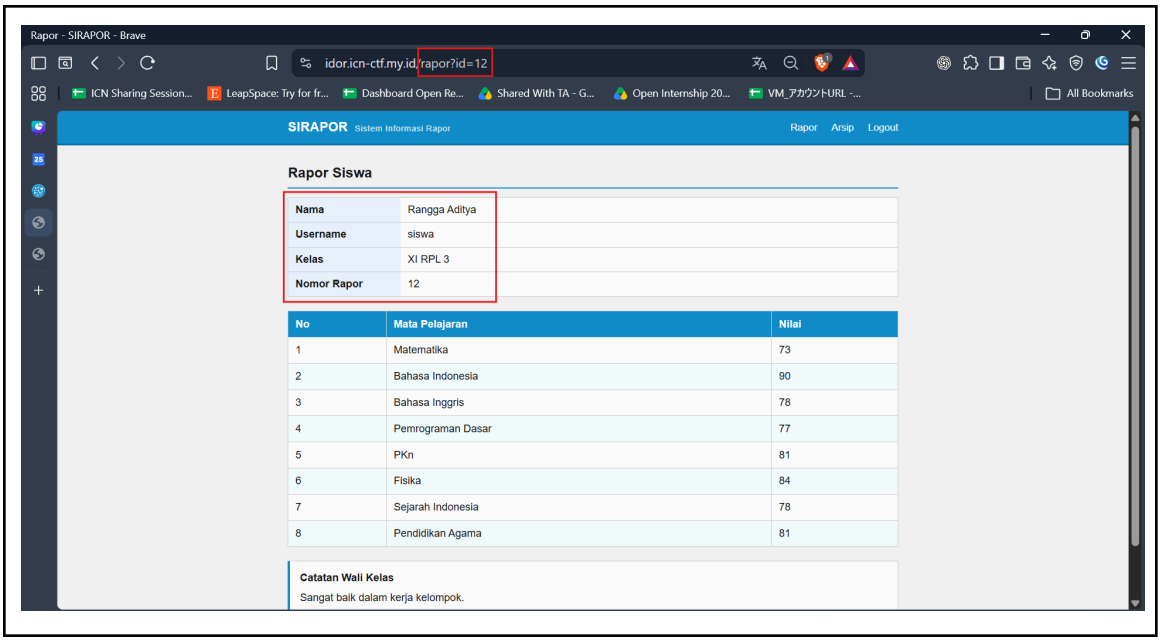
Masuk sebagai admin tanpa tahu passwordnya.

Petunjuk (hint):

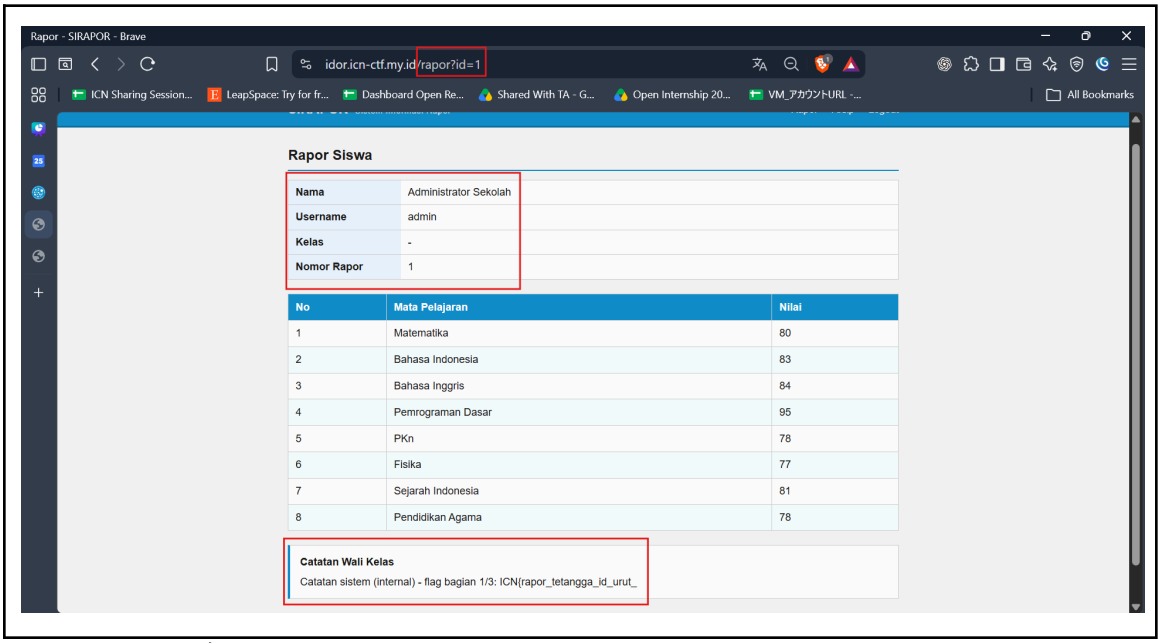
- **Hint 1:** Coba ubah angka pada parameter id di URL.
- **Hint 2**: Tanda kutip bisa merusak struktur query. Sekarang buat sisa query setelah usernamemu diabaikan.
- **Hint 3**: Akun admin biasanya dibuat lebih dulu, jadi coba ID kecil seperti 1

Langkah-langkah:

- Login dengan username **siswa** dan password **siswa123.**
- Buka soal dan lihat rapormu pada alamat seperti `/rapor?id=12.`



- Perhatikan parameter `id` pada address bar.
- Ganti angkanya menjadi 1, lalu tekan Enter.
- Rapor milik akun admin terbuka dan flag tampil.



FLAG PART 1/3 = ICN{rapor_tetangga_id_urut_

Part 2: Pintu Belakang

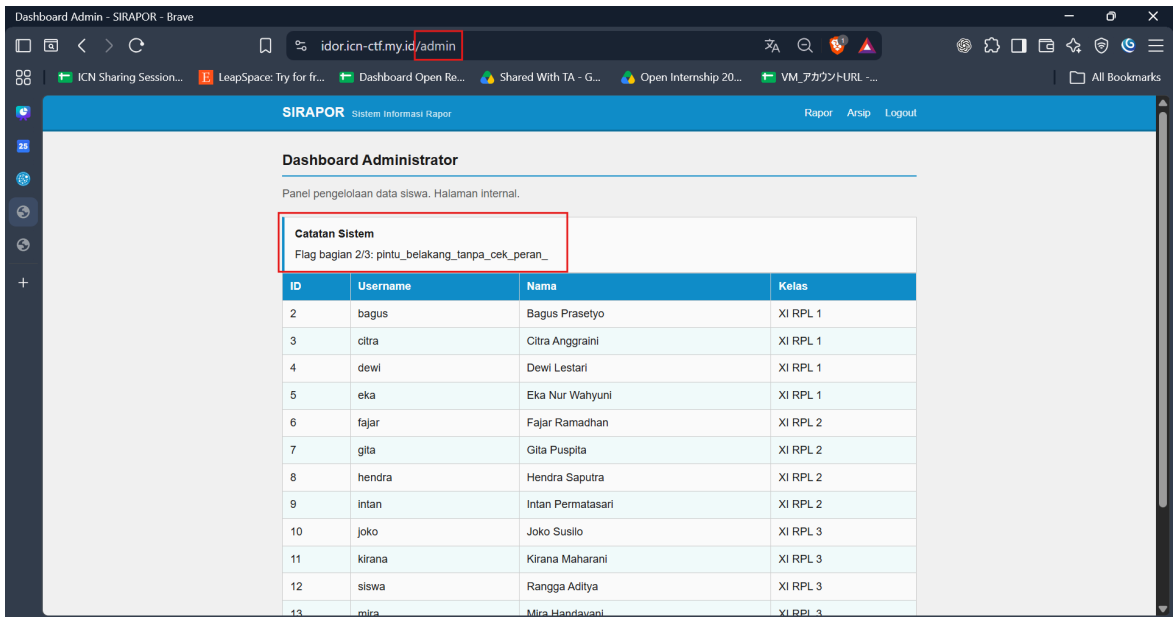
Ada halaman /admin yang seharusnya hanya untuk admin.

Petunjuk (hint):

- **Hint 1:** Halaman ini tidak muncul di menu navigasi, tetapi itu tidak berarti ia tidak bisa diakses.
- **Hint 2**: Coba akses /admin langsung di address bar tanpa login sebagai admin.
- **Hint 3**: Server hanya mengecek apakah path-nya ada, bukan apakah penggunanya berhak.

Langkah-langkah:

- Perhatikan menu navigasi. Halaman /admin tidak ada di sana.
- Ketik `/admin` di belakang alamat situs soal pada address bar, lalu tekan Enter.
- Halaman terbuka tanpa pengecekan peran.



Gambar x.x Isi file robots.txt

FLAG PART 2/3 = pintu_belakang_tanpa_cek_peran_

Part 3: Nomor Acak?

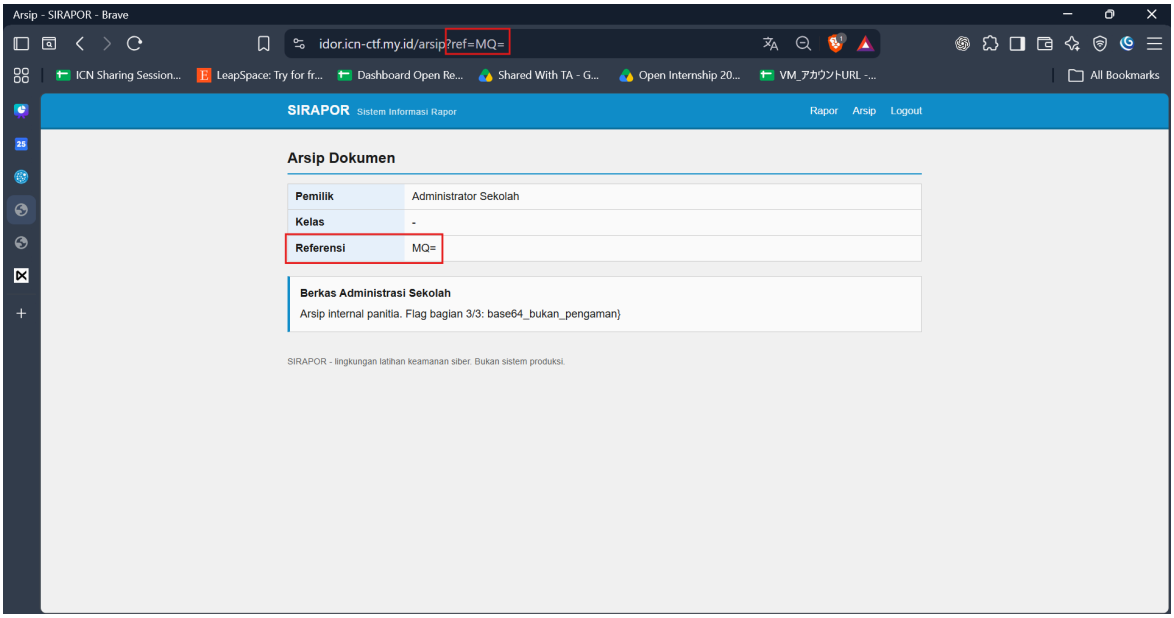
ID pada URL terlihat seperti teks acak, bukan angka biasa.

Petunjuk (hint):

- **Hint 1:** Teks acak itu mungkin bukan acak. Perhatikan pola karakternya (huruf, angka, dan tanda = di akhir).
- **Hint 2**: Pola seperti itu mirip hasil encoding base64.
- **Hint 3**: Decode teks itu dengan base64, lalu perhatikan angka yang muncul. Itu ID aslinya.

Langkah-langkah:

- Buka soal dan salin nilai `id` dari URL, misalnya `MTA=`.
- Buka DevTools, pilih tab Console, lalu ketik `atob('MTA=')` dan tekan Enter. Hasilnya `10`, yaitu ID aslinya.
- Buat ID baru dengan meng-encode angka lain, misalnya `btoa('1')`. Hasilnya `MQ==`.
- Ganti nilai `id` pada URL dengan hasil encode tadi, lalu tekan Enter.
- Data milik akun lain terbuka dan flag tampil.



Gambar 1.6 Melihat Response Headers di tab Network

FLAG PART 3/3 = base64_bukan_pengaman}

FLAG: ICN{rapor_tetangga_id_urut_pintu_belakang_tanpa_cek_peran_base64_bukan_pengaman}

Cek Pemahaman

1. Apa beda autentikasi dan otorisasi? Kenapa IDOR bisa terjadi walau autentikasi sudah benar?
2. Kenapa menyandikan ID dengan base64 saja tidak cukup untuk mencegah IDOR?

3. Digital Forensics

Setiap aktivitas di komputer dan jaringan meninggalkan jejak, mulai dari file yang dihapus, foto yang diunggah, sampai data yang dikirim saat membuka sebuah situs. Jejak inilah yang dicari penyidik ketika terjadi kejahatan siber. Pernahkah kamu bertanya-tanya bagaimana file yang sudah dihapus masih bisa dikembalikan, atau bagaimana sebuah password bisa bocor hanya karena login lewat Wi-Fi umum?

Modul ini membahas Digital Forensics, salah satu kategori dalam Capture The Flag (CTF). Kamu akan belajar dasar-dasar mencari dan membaca jejak digital, lalu mengenal Network Forensics dan Wireshark sebagai alat untuk menganalisis lalu lintas jaringan.

3.1 Pengantar Digital Forensics

Digital Forensics adalah proses mengumpulkan, memeriksa, dan menganalisis bukti digital untuk mengungkap apa yang terjadi pada sebuah sistem. Bukti digital bisa berupa file, gambar, log aktivitas, isi memori, atau rekaman lalu lintas jaringan. Tujuannya menjawab pertanyaan sederhana: apa yang terjadi, kapan, dan siapa pelakunya.

3.1.1 Prinsip Dasar

Bukti digital mudah berubah. Membuka sebuah file saja bisa mengubah catatan waktu aksesnya. Karena itu, seorang analis forensik memegang prinsip berikut.

- **Jangan ubah bukti asli:** Selalu bekerja pada salinan, bukan pada file atau perangkat aslinya.

- **Hash:** Sidik jari digital sebuah file, misalnya MD5 atau SHA-256. Jika isi file berubah sedikit saja, nilai hash ikut berubah, sehingga keaslian bukti bisa dibuktikan.
- **Chain of custody:** Catatan siapa yang memegang bukti, kapan, dan apa yang dilakukan terhadapnya.
- **Dokumentasi:** Setiap langkah analisis dicatat agar hasilnya bisa diperiksa ulang oleh orang lain.

3.1.2 Digital Forensics dalam CTF

Pada CTF, soal Digital Forensics biasanya berupa sebuah file yang harus diperiksa untuk menemukan flag. Flag tidak terlihat langsung, tetapi tersembunyi di dalam isi, struktur, atau data tambahan file tersebut.

- **File gambar atau dokumen:** Flag disembunyikan di metadata atau di dalam isi file.
- **File yang disamarkan:** Ekstensi file sengaja diubah sehingga tidak bisa dibuka seperti biasa.
- **Rekaman jaringan:** File .pcap berisi paket data yang dikirim lewat jaringan, dan flag terselip di antaranya.
- **Memory dump atau disk image:** Salinan isi memori atau hard disk yang harus ditelusuri.

3.2 Mengenal Jejak pada File

Sebuah file menyimpan lebih banyak informasi daripada yang terlihat saat dibuka. Dua hal yang biasanya diperiksa pertama kali adalah file signature dan metadata.

3.2.1 File Signature

Komputer biasanya mengenali jenis file dari ekstensinya, misalnya .jpg atau .pdf. Padahal ekstensi mudah diganti. Cara yang lebih akurat adalah melihat beberapa byte pertama file, yang disebut file signature atau magic bytes.

```
PNG  : 89 50 4E 47 0D 0A 1A 0A
JPEG : FF D8 FF
PDF  : 25 50 44 46   (%PDF)
ZIP  : 50 4B 03 04   (PK..)
```

Jika file bernama foto.txt ternyata diawali 89 50 4E 47, berarti file itu sebenarnya gambar PNG. Byte awal file dapat dilihat dengan perintah file atau xxd di Linux, atau dengan aplikasi hex editor.

3.2.2 Metadata

Metadata adalah data tentang data. Foto dari ponsel, misalnya, menyimpan informasi tambahan yang tidak terlihat saat gambar dibuka.

- **Waktu:** Kapan file dibuat dan terakhir diubah.
- **Perangkat:** Merek dan tipe kamera atau ponsel yang dipakai.
- **Lokasi:** Koordinat GPS tempat foto diambil, jika fitur lokasi aktif.
- **Pembuat:** Nama penulis pada dokumen Word atau PDF.

Metadata dapat dibaca dengan tool seperti exiftool. Di soal CTF, flag sering disembunyikan di kolom seperti Comment atau Author.

Hands-On 5: Analisis Metadata

Setiap foto digital tidak hanya berisi gambar. Di dalam filenya juga tersimpan metadata dalam format EXIF, yaitu merek dan model perangkat, waktu foto diambil, software yang dipakai untuk mengedit, bahkan koordinat GPS jika fitur lokasi pada kamera aktif. Informasi ini tidak terlihat saat foto dibuka, tetapi ikut terbawa ketika foto dibagikan sebagai file, misalnya lewat email, Google Drive, atau WhatsApp dengan opsi Dokumen.

Bagi analis digital forensics, metadata membantu menjawab pertanyaan kapan, di mana, dan dengan perangkat apa sebuah file dibuat. Salah satu alat yang memudahkan analisis ini adalah Aperi'Solve (aperisolve.com), platform online yang menjalankan beberapa alat analisis gambar sekaligus. Di antaranya exiftool untuk membaca metadata, serta zsteg, steghide, binwalk, dan strings untuk mencari data tersembunyi.

Pada hands-on ini, peserta berperan sebagai analis yang menerima sebuah poster. Peserta akan memeriksa informasi apa saja yang ikut terbawa di dalam file poster tersebut, lalu menemukan pesan tersembunyi (flag) di dalamnya. Hands-on ini cukup dikerjakan dengan browser, tanpa perlu memasang aplikasi tambahan.

Soal: Aku ICN

Seorang calon anggota ICN Lab membagikan poster ICN Internship miliknya dalam bentuk file. Sekilas isinya hanya poster biasa. Tapi benarkah tidak ada informasi lain yang ikut terbawa di dalam file-nya? Temukan flag-nya. File soal: aku_icn.jpg.

Petunjuk (Hint)

- **Hint 1:** Tulisan ICN pada poster bukan flag. Flag tersimpan di dalam file sebagai metadata.
- **Hint 2:** Unggah file ke Aperi'Solve, lalu perhatikan hasil dari exiftool.
- **Hint 3:** Cari kolom User Comment.

Langkah Pengerjaan

Langkah 1: Mengamati Gambar

- Unduh file aku_icn.jpg dari halaman soal di platform.
- Buka file dengan aplikasi penampil gambar biasa. Yang terlihat hanya poster ICN Internship, tanpa tulisan berformat ICN{...}.

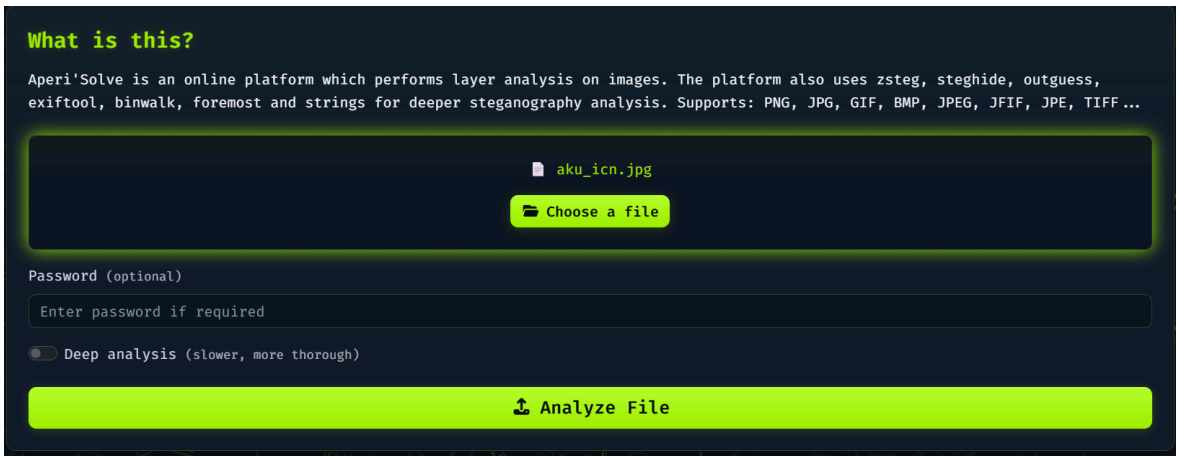
- Artinya flag tidak disembunyikan pada tampilan gambar, sehingga yang perlu diperiksa adalah isi file-nya.



Gambar 3.1 Tampilan file aku_icn.jpg

Langkah 2: Mengunggah File ke Aperi'Solve

- Buka https://www.aperisolve.com di browser.
- Seret (drag) file aku_icn.jpg ke kotak unggah, atau klik kotak tersebut untuk memilih file. Kolom password dibiarkan kosong.
- Jalankan analisis dan tunggu hingga hasilnya muncul.
- **Catatan:** File yang diunggah ke Aperi'Solve disimpan di server mereka. Jangan pernah mengunggah foto pribadi atau dokumen rahasia ke layanan analisis online.



Gambar 3.2 Mengunggah aku_icn.jpg ke Aperi'Solve

Langkah 3: Membaca Hasil Exiftool

- Gulir ke bagian Exiftool. Bagian ini berisi daftar metadata yang tersimpan di dalam file. Kolom yang perlu diperhatikan antara lain:
- Camera Model Name: iPhone 13, perangkat yang dipakai untuk memotret.
- Date/Time Original: 2026:09:02 15:47:33, waktu foto diambil.
- Artist: ICN Lab, pemilik atau pembuat file.
- Software: Canva, aplikasi yang dipakai untuk mengedit.
- GPS Position: 7 deg 57' 14.29" S, 112 deg 36' 52.16" E, lokasi foto diambil.
- User Comment: komentar yang ditambahkan ke file. Kolom inilah yang berisi flag. Salin flag lalu submit di platform.



Gambar 3.3 Hasil exiftool pada Aperi'Solve

FLAG: ICN{Ayo_Masuk_FILKOM_UB_terus_Join_ICN}

Langkah 4: Melacak Lokasi dari GPS

- Flag sudah ditemukan, tetapi perhatikan juga kolom GPS Position. Ketik koordinat tersebut di Google Maps dengan format 7°57'14.3"S 112°36'52.2"E atau dalam bentuk desimal -7.95397, 112.61449.
- Google Maps menunjukkan lokasi foto diambil, yaitu gedung Fakultas Ilmu Komputer Universitas Brawijaya (FILKOM UB), Malang.
- Hanya dari satu file, orang lain bisa mengetahui perangkat yang dipakai, kapan foto diambil, dan di mana lokasinya.



Gambar 3.4 Koordinat GPS dari metadata ditampilkan di Google Maps

Untuk mencegah kebocoran seperti ini:

- Matikan fitur lokasi (geotag) pada aplikasi kamera jika tidak diperlukan.
- Hapus metadata sebelum membagikan file. Di Windows, klik kanan file, pilih Properties > Details > Remove Properties and Personal Information. Dengan exiftool, jalankan exiftool -all= foto.jpg.
- Banyak media sosial menghapus metadata secara otomatis, tetapi foto yang dikirim sebagai file atau dokumen biasanya tetap membawa metadata lengkap.

3.3 Network Forensics dan Wireshark

Bayangkan seorang siswa login ke sebuah situs memakai Wi-Fi umum di kafe. Situs itu masih memakai HTTP biasa, bukan HTTPS. Orang lain di jaringan yang sama yang merekam lalu lintas data bisa melihat username dan password siswa tersebut sebagai teks biasa. Rekaman seperti inilah yang diperiksa dalam Network Forensics.

3.3.1 Konsep

Network Forensics adalah cabang Digital Forensics yang menganalisis lalu lintas jaringan. Data yang dikirim lewat jaringan dipecah menjadi potongan kecil yang disebut paket. Paket-paket ini dapat direkam, lalu dianalisis untuk mengetahui siapa berkomunikasi dengan siapa dan data apa yang dikirim.

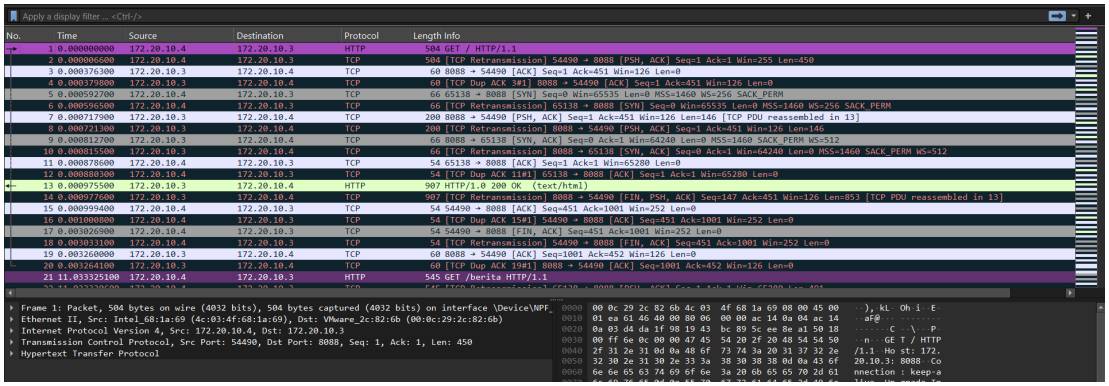
- **Paket:** Potongan data yang dikirim lewat jaringan. Setiap paket berisi alamat pengirim, alamat tujuan, dan isi data.
- **Protokol:** Aturan komunikasi, misalnya HTTP untuk web, DNS untuk mencari alamat situs, dan FTP untuk transfer file.
- **File .pcap:** Format file hasil rekaman paket jaringan. Soal Network Forensics di CTF hampir selalu berupa file ini.

3.3.2 Mengenal Wireshark

Wireshark adalah aplikasi gratis untuk merekam dan membaca paket jaringan. Wireshark dapat membuka file .pcap dan menampilkan isi setiap paket secara rinci. Tampilan utamanya terbagi menjadi tiga bagian.

- **Packet List:** Daftar semua paket, lengkap dengan waktu, alamat IP, protokol, dan ringkasan isinya.
- **Packet Details:** Rincian paket yang dipilih, disusun per lapisan protokol.

- **Packet Bytes:** Isi mentah paket dalam bentuk heksadesimal dan teks.



Gambar 3.5 Tampilan utama Wireshark

Jumlah paket dalam satu rekaman bisa mencapai ribuan. Gunakan display filter untuk menampilkan paket yang dibutuhkan saja: ketik filter pada kolom di bagian atas, lalu tekan Enter.

```
http
ip.addr == 172.20.10.3
tcp.port == 21
http.request.method == "POST"
frame contains "ICN"
```

Fitur lain yang sering dipakai adalah Follow TCP Stream (klik kanan pada paket, lalu pilih Follow > TCP Stream). Fitur ini menyusun ulang potongan paket menjadi satu percakapan utuh sehingga lebih mudah dibaca. Untuk mengambil file yang dikirim lewat HTTP, gunakan menu File > Export Objects > HTTP.

3.3.3 Kenapa Bisa Terjadi

```
POST /login.php HTTP/1.1
Host: situs-latihan.example
Content-Type: application/x-www-form-urlencoded

username=siswa01&password=rahasia123
```

Protokol lama seperti HTTP, FTP, dan Telnet mengirim data apa adanya tanpa enkripsi. Siapa pun yang dapat merekam paket di jaringan yang sama bisa membaca isinya, termasuk password seperti pada contoh di atas.

3.3.4 Cara Mencegah

- Gunakan protokol yang terenkripsi: HTTPS untuk web, SSH sebagai pengganti Telnet, dan SFTP sebagai pengganti FTP.
- Hindari login ke akun penting saat memakai Wi-Fi umum, atau gunakan VPN.
- Pastikan ada ikon gembok di address bar browser sebelum mengisi username dan password.

Hands-On 6: Network Forensics

Data yang dikirim lewat HTTP tidak dienkripsi. Siapa pun yang dapat merekam lalu lintas di jaringan yang sama, misalnya di Wi-Fi umum, bisa membaca isinya apa adanya. Data yang dapat bocor dengan cara ini antara lain username dan password, cookie sesi yang bisa dipakai untuk mengambil alih akun, isi form seperti nama, email, dan nomor telepon, serta alamat halaman yang dikunjungi.

Digital forensics membantu menjawab pertanyaan setelah kebocoran terjadi atau dicurigai. Dari file rekaman jaringan (.pcap), analis dapat memastikan data apa saja yang terkirim tanpa perlindungan, kapan dan ke server mana data itu dikirim, serta akun mana yang terdampak sehingga password-nya harus segera diganti. Temuan tersebut juga menjadi bukti bahwa layanan itu perlu beralih ke HTTPS.

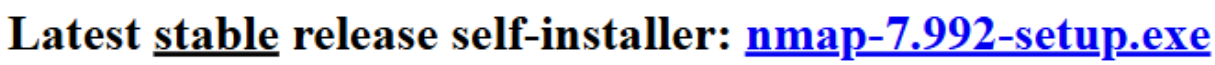
Pada hands-on ini, peserta berperan sebagai analis forensik. Peserta akan memeriksa rekaman jaringan saat seorang pengguna login ke sebuah situs, lalu menelusuri paket HTTP dengan Wireshark untuk menemukan kredensial yang bocor. Pastikan Wireshark sudah terpasang di laptop sebelum mulai.

Soal: Login Bocor

Seorang pengguna login ke situs latihan melalui jaringan yang sedang direkam. Temukan password yang ia kirimkan. File soal: login.pcap.

Instalasi Netcat di Windows

https://nmap.org/download.html#windows



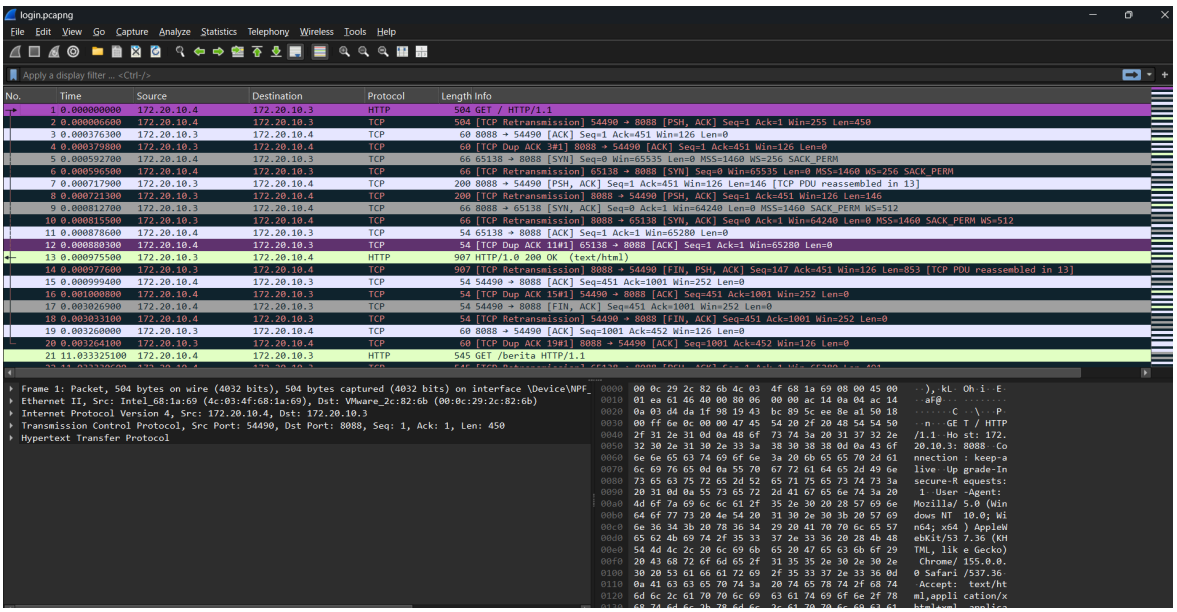
Petunjuk (Hint)

- **Hint 1:** Data dari form login biasanya dikirim dengan method POST.
- **Hint 2:** Gunakan display filter http.request.method == "POST" untuk menyaring request.
- **Hint 3:** Isi form login dapat dilihat pada bagian HTML Form URL Encoded di panel Packet Details.

Langkah Pengerjaan

Langkah 1: Membuka File .pcap

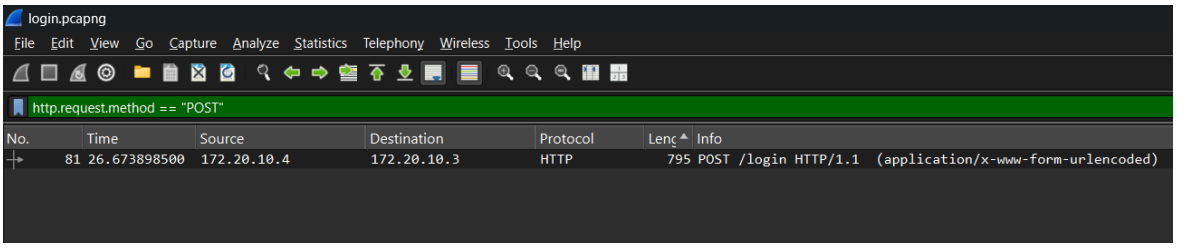
- Unduh file login.pcap dari halaman soal di platform.
- Buka Wireshark, pilih menu File > Open, lalu pilih file login.pcap. File juga bisa langsung diseret (drag) ke jendela Wireshark.
- Amati Packet List. Kolom Protocol menunjukkan jenis paket, misalnya TCP dan HTTP.



Gambar 3.6 File login.pcap dibuka di Wireshark

Langkah 2: Menyaring Request Login

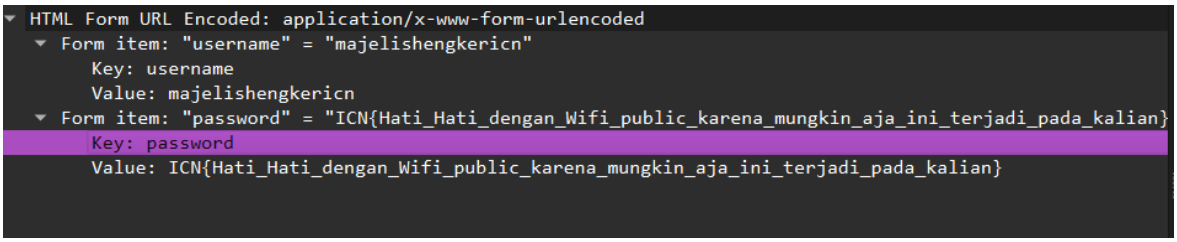
- Ketik http pada kolom display filter di atas Packet List, lalu tekan Enter. Sekarang hanya paket HTTP yang tampil.
- Persempit dengan filter http.request.method == "POST". Request login memakai POST karena mengirim data form ke server.
- Cari paket yang kolom Info-nya berisi POST /login (atau path login lain), lalu klik paket tersebut.



Gambar 3.7 Hasil filter request POST

Langkah 3: Membaca Username dan Password

- Pada panel Packet Details, buka bagian HTML Form URL Encoded di urutan paling bawah.
- Bagian ini berisi pasangan nama dan nilai dari form login, yaitu username dan password. Nilai password adalah flag.
- Cara lain: klik kanan paket, pilih Follow > HTTP Stream. Jendela baru menampilkan isi request lengkap, termasuk baris username=...&password=....
- Karakter khusus pada form dikodekan dengan URL encoding. Jika flag tampil sebagai ICN%7B...%7D, ganti %7B menjadi { dan %7D menjadi }. Salin flag lalu submit di platform.



Gambar 3.8 Isi form login pada panel Packet Details



Gambar 3.9 Request login pada jendela Follow HTTP Stream

FLAG:
ICN{Hati_Hati_dengan_Wifi_public_karena_mungkin_aja_ini_terjadi_pada_kalian}

Hands-On 7: Investigasi Serangan SQL Injection

Pada Hands-On 3, peserta berperan sebagai penyerang yang menyisipkan SQL Injection ke form login dan fitur pencarian. Serangan seperti itu meninggalkan jejak. Jika lalu lintas jaringan ke server direkam, setiap request dari penyerang dan setiap respons dari server ikut tersimpan di file .pcap, termasuk payload, pesan error, dan data yang berhasil dicuri.

Dari rekaman tersebut, analis forensik dapat menyusun ulang serangan langkah demi langkah: siapa penyerangnya, server mana yang diserang, akun apa yang berhasil dibobol, dan data apa yang bocor. Jawaban atas pertanyaan ini

menentukan langkah pemulihan, misalnya akun mana yang password-nya harus segera diganti dan celah mana yang harus ditutup lebih dulu.

Pada hands-on ini, peserta kembali berperan sebagai analis forensik dan menyelidiki serangan yang sama dengan yang pernah dipraktikkan di Hands-On 3. Peserta akan menelusuri rekaman serangan dengan Wireshark, lalu menjawab tujuh pertanyaan investigasi di server quiz menggunakan netcat (nc). Flag diberikan setelah semua jawaban benar.

Soal: Perpustakaan ICN Lab Diserang

Perpustakaan ICN kemarin diserang dengan metode SQL injection. Carilah si penyerang ngapain aja mulai dari login dan apa data yang sensitif dan jawab melalui pertanyaan pada netcat. File soal: perpus_diserang.pcap.

1. Berapa alamat IP penyerang?
2. Berapa alamat IP web server yang diserang?
3. Payload apa yang berhasil dipakai penyerang untuk masuk ke akun korban?
4. Penyerang masuk sebagai akun apa?
5. Berapa kali penyerang gagal login sebelum berhasil?
6. Berapa jumlah kolom pada query fitur pencarian?
7. Berapa password akun pustakawan yang dicuri penyerang?

Petunjuk (Hint)

- **Hint 1:** Request dari penyerang berisi karakter yang tidak dipakai pengguna biasa, misalnya tanda kutip ('). Di alamat URL, tanda kutip ditulis sebagai %27.

- **Hint 2:** Gunakan display filter http.request.method == "POST" untuk melihat semua percobaan login.
- **Hint 3:** Kode status respons menunjukkan hasil setiap request: 200 berarti berhasil, 401 berarti login gagal, dan 500 berarti query error.

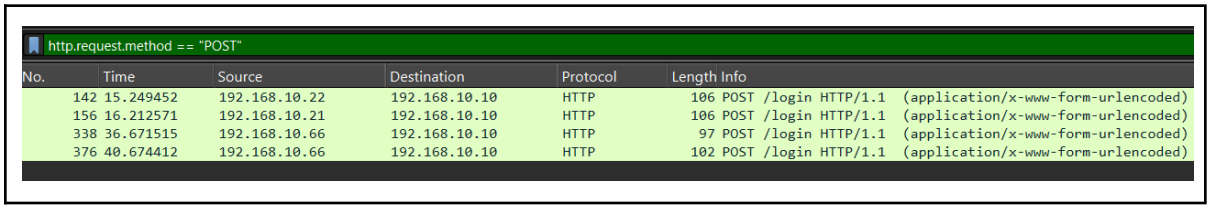
Langkah Pengerjaan

Langkah 1: Mencari Payload Login dan Mengenali Penyerang

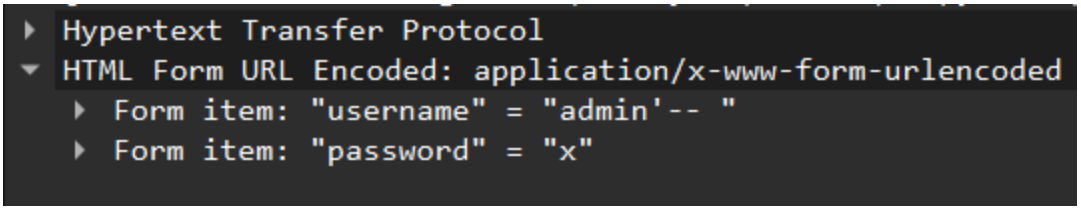
- Unduh file perpus_diserang.pcap dari halaman soal di platform, lalu buka di Wireshark.
- Serangan dimulai dari form login. Data form login dikirim dengan method POST, jadi tampilkan semua percobaan login dengan filter berikut:

```
http.request.method == "POST"
```

- Klik setiap paket, lalu buka bagian HTML Form URL Encoded di panel Packet Details. Wireshark sudah men-decode isi form, sehingga nilai username dan password bisa dibaca langsung.
- Bandingkan payload yang dikirim setiap alamat IP. Pengguna biasa mengirim username dan password yang wajar, sedangkan penyerang mengirim payload SQL Injection: username yang berisi tanda kutip (') dan --, sama seperti payload di Hands-On 3 Part 1.
- Alamat pada kolom Source milik paket yang berisi payload SQL Injection adalah alamat IP penyerang (pertanyaan 1). Alamat pada kolom Destination adalah web server yang diserang (pertanyaan 2).



Gambar 3.10 Hasil filter request POST



Gambar 3.11 Payload SQL Injection Oleh Penyerang

Langkah 2: Menganalisis Login dengan Follow HTTP Stream

- Klik kanan paket POST pertama dari penyerang, lalu pilih Follow > HTTP Stream (atau Follow > TCP Stream). Jendela baru menampilkan request dari penyerang dan respons dari server dalam satu percakapan.
- Baca baris status dan isi respons. Respons 401 Unauthorized dengan pesan "Username atau password salah" berarti login gagal, sedangkan respons 200 OK dengan pesan "Login berhasil" berarti penyerang berhasil masuk.
- Ulangi untuk setiap paket POST dari penyerang. Payload pada login yang mendapat respons 200 adalah jawaban pertanyaan 3. Akun yang dimasuki penyerang terlihat dari username pada payload tersebut dan dari pesan selamat datang pada respons (pertanyaan 4).
- Hitung berapa kali penyerang mendapat respons 401 sebelum mendapat respons 200 (pertanyaan 5). Login gagal dari alamat IP lain bukan bagian dari serangan, jadi jangan ikut dihitung.

```
POST /login HTTP/1.1
Accept-Encoding: identity
Content-Type: application/x-www-form-urlencoded
Content-Length: 31
Host: 192.168.10.10
User-Agent: Python-urllib/3.13
Connection: close

username=admin%27--+&password=x
HTTP/1.0 401 Unauthorized
Server: PerpusICN/1.0
Date: Thu, 22 Oct 2026 06:42:16 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1093
```

Gambar 3.12 Login gagal (401) pada jendela Follow HTTP Stream

```
POST /login HTTP/1.1
Accept-Encoding: identity
Content-Type: application/x-www-form-urlencoded
Content-Length: 36
Host: 192.168.10.10
User-Agent: Python-urllib/3.13
Connection: close

username=pustakawan%27--+&password=x
HTTP/1.0 200 OK
Server: PerpusICN/1.0
Date: Thu, 22 Oct 2026 06:42:20 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1004
Set-Cookie: sesi=ccca8c091964abf66bd4dc2f3ce55c79; Path=/; HttpOnly
```

Gambar 3.13 Login berhasil (200) pada jendela Follow HTTP Stream

Langkah 3: Menelusuri Serangan Lanjutan dari Penyerang

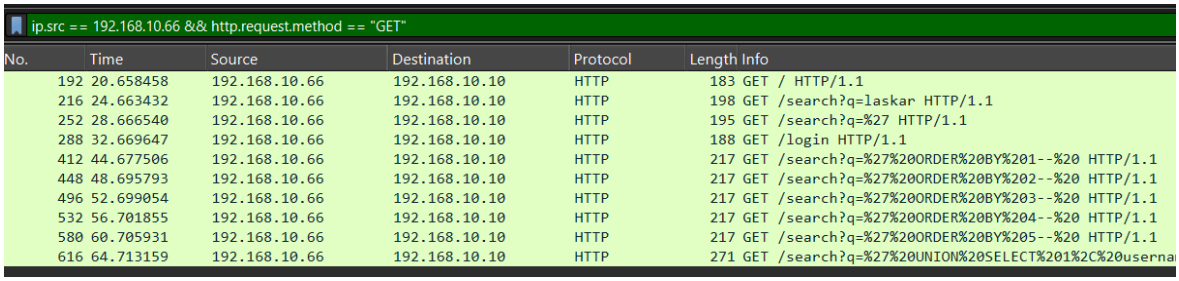
- Alamat IP penyerang sudah diketahui dari Langkah 1. Tampilkan semua request GET yang dikirim penyerang dengan filter berikut:

```
ip.src == 192.168.10.66 && http.request.method == "GET"
```

- Filter ini memakai GET, bukan POST, karena setelah berhasil login penyerang beralih ke fitur pencarian buku (/search). Form pencarian mengirim kata kunci dengan method GET karena dia meminta data dari server yang tidak mengubah apapun di sisi server(berbeda dengan POST), sehingga input penyerang ikut tertulis di alamat URL, misalnya /search?q=.... Method POST hanya dipakai oleh form login, yang mengirim data di dalam body request, dan request tersebut sudah diperiksa di Langkah 1 dan 2.
- Input penyerang di alamat URL ditulis dengan URL encoding. Gunakan daftar berikut untuk membacanya:

```
%27 = ' (tanda kutip)
%20 = spasi
%2C = , (koma)
```

- Contoh: %27%20ORDER%20BY%201--%20 dibaca sebagai ' ORDER BY 1-- .



ip.src == 192.168.10.66 && http.request.method == "GET"

No.	Time	Source	Destination	Protocol	Length	Info
192	20.658458	192.168.10.66	192.168.10.10	HTTP	183	GET / HTTP/1.1
216	24.663432	192.168.10.66	192.168.10.10	HTTP	198	GET /search?q=laskar HTTP/1.1
252	28.666540	192.168.10.66	192.168.10.10	HTTP	195	GET /search?q=%27 HTTP/1.1
288	32.669647	192.168.10.66	192.168.10.10	HTTP	188	GET /login HTTP/1.1
412	44.677506	192.168.10.66	192.168.10.10	HTTP	217	GET /search?q=%27%20ORDER%20BY%201--%20 HTTP/1.1
448	48.695793	192.168.10.66	192.168.10.10	HTTP	217	GET /search?q=%27%20ORDER%20BY%202--%20 HTTP/1.1
496	52.699054	192.168.10.66	192.168.10.10	HTTP	217	GET /search?q=%27%20ORDER%20BY%203--%20 HTTP/1.1
532	56.701855	192.168.10.66	192.168.10.10	HTTP	217	GET /search?q=%27%20ORDER%20BY%204--%20 HTTP/1.1
580	60.705931	192.168.10.66	192.168.10.10	HTTP	217	GET /search?q=%27%20ORDER%20BY%205--%20 HTTP/1.1
616	64.713159	192.168.10.66	192.168.10.10	HTTP	271	GET /search?q=%27%20UNION%20SELECT%201%2C%20userna

Gambar 3.14 Request GET yang dikirim penyerang

- Penyerang mengirim ' ORDER BY 1-- , ' ORDER BY 2-- , dan seterusnya untuk mencari jumlah kolom query. Teknik ini sama dengan yang dipakai di Hands-On 3 Part 2.
- Filter di atas hanya menampilkan request. Untuk melihat respons dari server, klik kanan paket lalu pilih Follow > HTTP Stream. Respons yang berisi pesan Unknown column menandakan angka ORDER BY sudah melebihi jumlah kolom. Jumlah kolom adalah angka terakhir sebelum error muncul (pertanyaan 6).



Gambar 3.15 Pesan error Unknown column pada respons server

- Request terakhir dari penyerang berisi UNION SELECT. Decode URI-nya untuk mengetahui tabel dan kolom yang diambil penyerang.
- Buka responsnya dengan Follow > HTTP Stream. Data dari tabel tersebut ikut tampil di tabel hasil pencarian, di bawah daftar buku. Cari baris milik akun yang dimasuki penyerang di Langkah 2. Password akun itu adalah jawaban pertanyaan 7.



Gambar 3.16 Data akun pada respons UNION SELECT

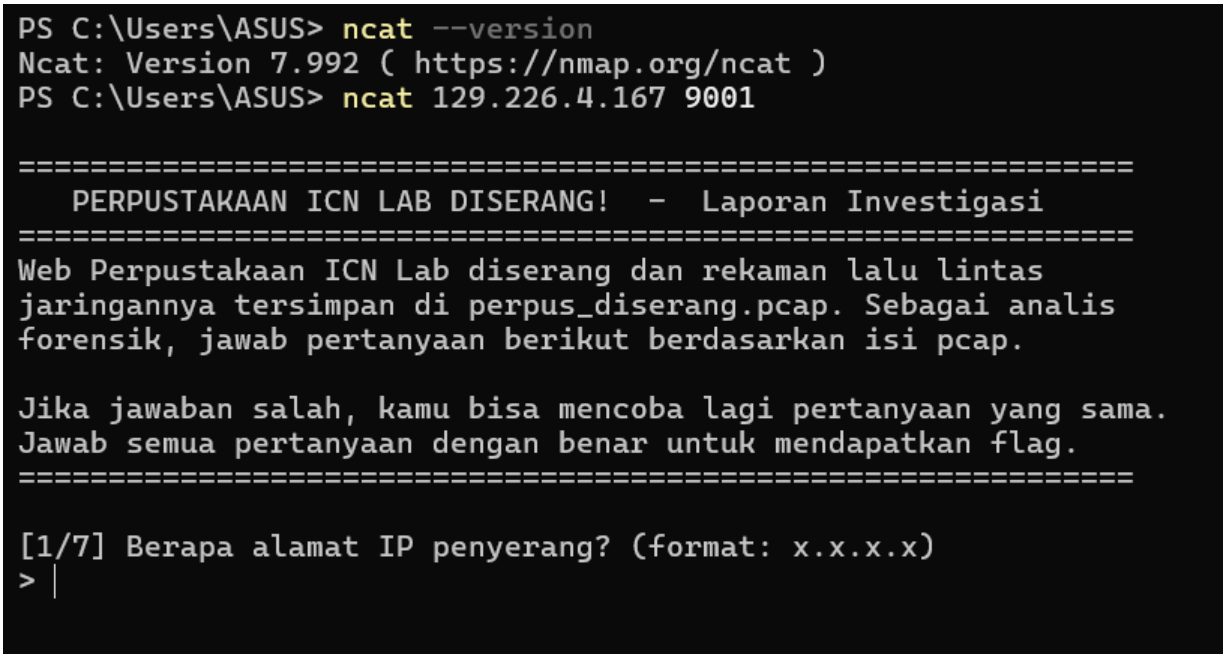
Sampai di sini, ketujuh jawaban sudah ditemukan. Langkah berikutnya adalah mengirim jawaban ke server quiz.

Langkah 4: Menjawab Pertanyaan di Server Quiz

- Sambungkan ke server quiz dengan perintah berikut. Alamat dan port server tercantum di halaman soal.

```
nc <alamat-server> <port>
```

- Jawab setiap pertanyaan sesuai temuan pada Langkah 1 sampai 3. Huruf besar dan kecil tidak dibedakan. Jika jawaban salah, pertanyaan yang sama akan ditanyakan lagi.
- Jawaban harus sudah di-decode. Server menolak jawaban yang masih berisi URL encoding seperti %27.
- Setelah semua jawaban benar, server menampilkan flag.
- **Catatan:** Windows tidak menyediakan nc secara bawaan. Gunakan ncat yang ikut terpasang bersama Nmap, atau jalankan nc dari WSL atau Linux.



Gambar 3.17 Menjawab pertanyaan di server quiz dengan netcat

FLAG: ICN{Wireshark_Bisa_Digunakan_untuk_Analisis_serangan_dari_segi_jaringan_dan_Protokol}

Cek Pemahaman

1. Apa itu metada?
2. Kenapa password yang dikirim lewat HTTP bisa terlihat di Wireshark, sedangkan lewat HTTPS tidak?
3. Request login pada login.pcap memakai method POST. Kenapa Login pada suatu web server menggunakan POST dan bukan GET?
4. Petunjuk apa saja di perpus_diserang.pcap yang membedakan alamat IP penyerang dari pengguna biasa?
5. Penyerang mengirim `ORDER BY 1` sampai `ORDER BY 5` secara berurutan. Bagaimana respons server memberi tahu analis jumlah kolom pada query pencarian?

4. Cryptography

Setiap hari kita mengirim pesan, login ke akun, dan menyimpan password. Semua itu bergantung pada satu hal: data rahasia hanya boleh dibaca oleh orang yang berhak. Pernahkah kamu bertanya-tanya bagaimana sebuah pesan rahasia bisa dibongkar tanpa tahu kuncinya, atau bagaimana password yang sudah "diacak" tetap bisa ketahuan?

Modul ini membahas Cryptography, salah satu kategori dalam Capture The Flag (CTF). Kamu akan belajar dua hal: membongkar pesan yang dikunci dengan cipher klasik, dan menebak password dari hash yang bocor. Semua soal cukup dikerjakan lewat browser, tanpa menulis program. Setiap bab terdiri dari materi singkat dan sesi Hands-On yang langkah-langkahnya bisa diikuti satu per satu.

4.1 Pengantar Cryptography

Cryptography adalah kategori CTF yang berfokus pada membongkar pesan yang disamarkan atau dikunci untuk mendapatkan flag. Soalnya biasanya berupa teks berisi tulisan acak. Tugasmu adalah mengenali cara pesan itu dibuat, lalu membaliknya. Tujuan akhirnya bukan sekadar membaca pesan, tetapi memahami kenapa sebuah cara pengamanan lemah dan apa penggantinya yang benar.

4.1.1 Etika dan Aturan Main

- Semua teknik di modul ini hanya boleh dipraktikkan di platform CTF kegiatan ini.
- Mencoba membuka pesan, akun, atau database milik orang lain tanpa izin dapat dipidana menurut hukum di Indonesia (antara lain UU ITE dan KUHP).
- Jika kamu menemukan password atau data rahasia yang bocor di luar platform latihan, jangan dipakai. Laporkan ke guru atau pengelola sistem.

4.1.2 Encoding, Enkripsi, dan Hashing

Tiga istilah ini sering tertukar, padahal tujuannya berbeda. Kesalahan paling umum adalah menganggap data sudah aman hanya karena tulisannya tidak terbaca.

Jenis	Tujuan	Butuh kunci?	Bisa dibalik?	Contoh
Encoding	Mengubah format data supaya bisa dikirim atau disimpan	Tidak	Ya, oleh siapa saja	Base64, Hex
Enkripsi	Merahasiakan data	Ya	Ya, hanya oleh pemegang kunci	Caesar, Vigenère, AES
Hashing	Membuat "sidik jari" data	Tidak	Tidak	MD5, SHA-256

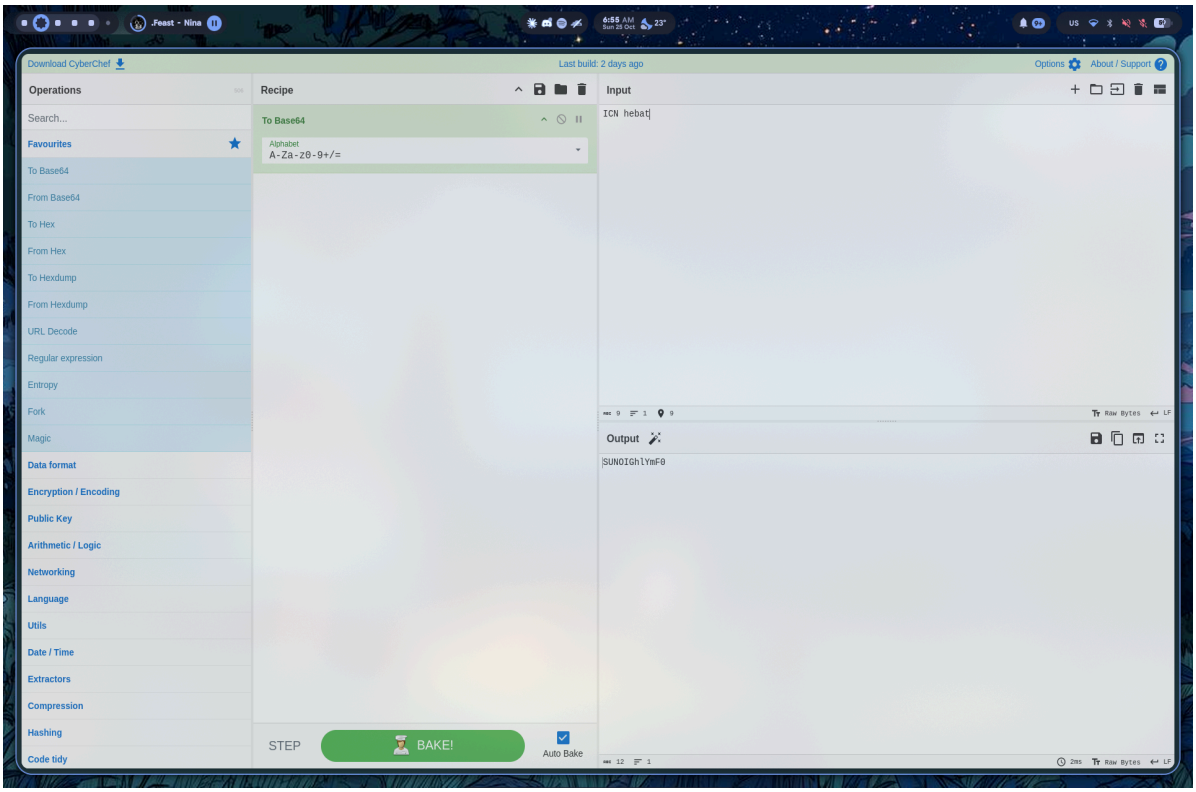
Pegangan sederhananya: encoding itu ganti bahasa, enkripsi itu gembok, hashing itu sidik jari. Modul ini membahas dua yang terakhir.

4.1.3 Alat yang Dipakai: CyberChef

CyberChef adalah situs gratis untuk mengolah data, dapat dibuka di https://gchq.github.io/CyberChef/. Hampir semua soal di modul ini cukup dikerjakan dengan CyberChef.

- **Operations (kiri):** Daftar operasi, misalnya ROT13 atau Vigenère Decode. Ketik nama operasi di kolom pencarian.

- **Recipe (tengah):** Operasi yang dipilih disusun di sini. Seret operasi dari kiri ke kolom Recipe.
- **Input dan Output (kanan):** Tempel teks soal di Input, hasilnya langsung tampil di Output.



Gambar 4.1 Tampilan CyberChef beserta bagian-bagiannya

4.1.4 Pola Pikir Peserta

Setiap kali melihat teks acak, tanyakan: karakter apa saja yang dipakai, berapa panjangnya, dan bagian mana yang sudah aku ketahui isinya? Flag selalu berformat ICN{...}. Pengetahuan kecil ini sering menjadi kunci untuk membongkar seluruh pesan.

4.2 Cipher Klasik

Lebih dari 2.000 tahun lalu, Julius Caesar mengirim pesan perang dengan menggeser setiap huruf tiga posisi: A menjadi D, B menjadi E, dan seterusnya. Pada zamannya cara ini cukup ampuh, karena sedikit orang yang bisa membaca. Sekarang, komputer bisa mencoba semua kemungkinan geseran dalam waktu kurang dari satu detik.

4.2.1 Konsep

Cipher adalah cara mengubah pesan asli (plaintext) menjadi pesan acak (ciphertext) memakai sebuah kunci. Cipher klasik bekerja pada huruf, sehingga angka dan simbol seperti {, }, dan _ tidak berubah.

Caesar cipher menggeser setiap huruf sejumlah posisi yang sama. Kuncinya adalah besar geseran. Contoh dengan geseran 3:

Plaintext	**H**	**A**	**L**	**O**
Digeser 3	K	D	O	R

Karena alfabet hanya punya 26 huruf, Caesar cipher hanya punya 25 kemungkinan kunci. Semuanya bisa dicoba satu per satu. Cara ini disebut brute force. ROT13 adalah Caesar cipher dengan geseran 13.

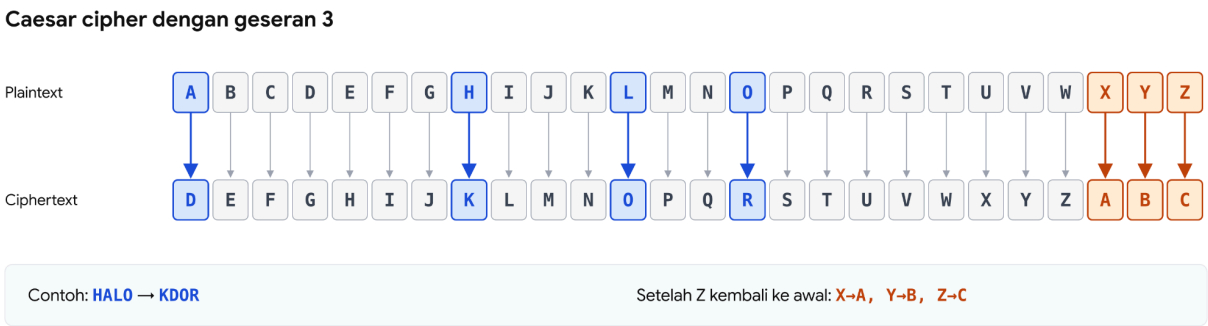
Vigenère cipher menggeser setiap huruf dengan besar yang berbeda-beda, mengikuti huruf-huruf sebuah kata kunci. Huruf A berarti geser 0, B geser 1, sampai Z geser 25. Jika kata kuncinya lebih pendek dari pesan, kunci diulang dari awal. Contoh dengan kunci SEKOLAH:

Plaintext	**H**	**A**	**L**	**O**

Huruf kunci	S	E	K	O
Besar geseran	18	4	10	14
Ciphertext	Z	E	V	C

Vigenère lebih sulit ditebak daripada Caesar karena huruf yang sama bisa berubah menjadi huruf yang berbeda. Meski begitu, jika kata kuncinya pendek atau mudah ditebak, pesannya tetap bisa dibongkar.

Cipher klasik juga bisa dibongkar dengan **analisis frekuensi**. Pada teks bahasa Indonesia, huruf A muncul paling sering, disusul N, I, dan E. Jika satu huruf di ciphertext muncul jauh lebih sering dari yang lain, kemungkinan besar itu adalah A.



Gambar 4.2 Pergeseran huruf pada Caesar cipher

4.2.2 Kenapa Bisa Terjadi

```
// simpan_catatan.php (TIDAK aman)
$rahasia = str_rot13($_POST['catatan']); // dianggap sudah dienkripsi
simpanKeDatabase($rahasia);
```

Developer mengira ROT13 sudah cukup untuk merahasiakan catatan. Padahal cipher klasik punya kunci yang sangat sedikit kemungkinannya, dan pola huruf pada plaintext tetap terlihat di ciphertext. Jika potongan plaintext sudah diketahui, misalnya awalan ICN{, kuncinya bisa langsung ditebak.

4.2.3 Cara Mencegah

- Jangan membuat algoritma enkripsi sendiri atau memakai cipher klasik untuk data sungguhan.
- Gunakan algoritma modern yang sudah teruji, seperti AES, lewat library resmi bahasa pemrograman yang dipakai.
- Simpan kunci enkripsi di server dan jangan pernah ditulis langsung di kode yang dikirim ke client.

Hands-On 8: Cipher Klasik

Pada sesi hands-on ini, peserta akan membongkar dua cipher klasik. Petunjuk utamanya: semua flag diawali ICN{, dan cipher klasik tidak mengubah simbol. Setiap part adalah soal terpisah dengan flag sendiri.

Part 1: Salam dari Kaisar

Seorang kaisar mengirim pesan, tetapi besar geserannya tidak diberitahu: PJU{rhpzhy_rhsho_zhth_iybal_mvyjl}

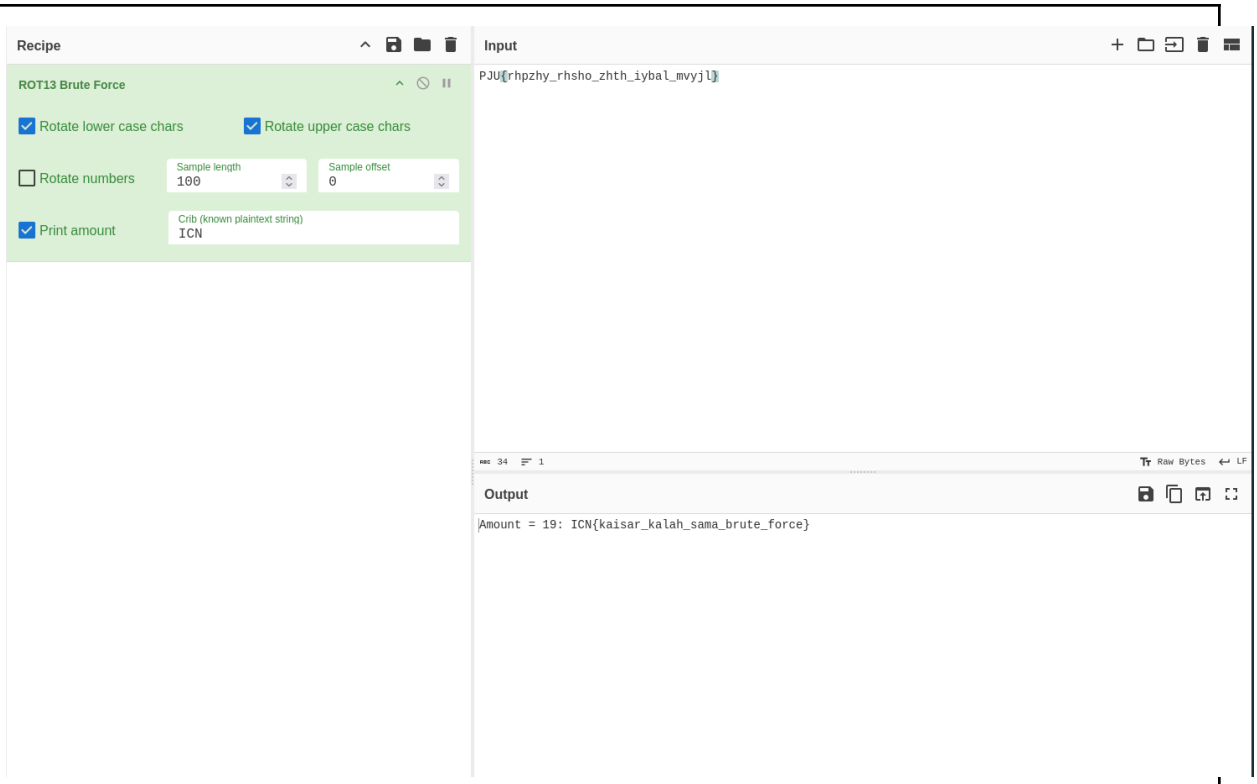
Petunjuk (hint):

- **Hint 1:** Tanda { tidak berubah, jadi PJU pasti hasil geseran dari ICN.
- **Hint 2:** Hitung jarak dari I ke P di alfabet.
- **Hint 3:** Gunakan operasi ROT13 Brute Force di CyberChef dengan Crib ICN.

Langkah-langkah:

- Buka soal Salam dari Kaisar di platform, lalu salin teks soal.
- Tempel teks soal di kolom Input CyberChef.
- Tambahkan operasi ROT13 Brute Force ke Recipe.
- Isi kolom Crib (known plaintext string) dengan ICN. Output hanya menampilkan geseran yang menghasilkan ICN.

- Cara lain: pakai operasi ROT13, lalu ubah nilai Amount sampai hasilnya diawali ICN{.
- Salin flag, lalu submit di platform.



Gambar 4.3 Mencoba semua geseran Caesar dengan ROT13 Brute Force

`FLAG: ICN{kaisar_kalah_sama_brute_force}`

Part 2: Kunci Kata

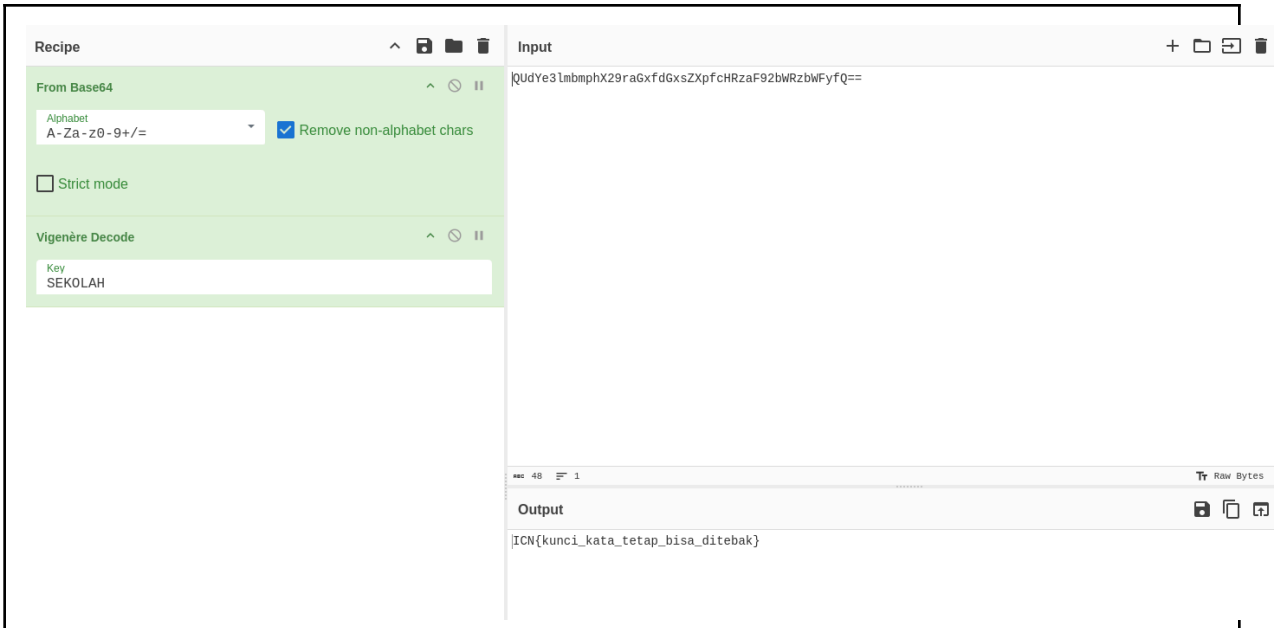
Pesan berikut dibungkus dua lapis: QUdYe3lmbmphX29raGxfdGxsZXpfcHRzaF92bWRzbWFyfQ==. Lapis luarnya Base64, yaitu encoding yang biasa dipakai untuk mengirim data sebagai teks. Lapis dalamnya Vigenère. Deskripsi soal berbunyi: "Kuncinya adalah tempat kamu belajar setiap hari, ditulis dengan huruf kapital."

Petunjuk (hint):

- **Hint 1:** Huruf besar, huruf kecil, angka, dan == di akhir adalah ciri Base64. Gunakan operasi From Base64.
- **Hint 2:** Hasil decode diawali AGX{. Itu lapis Vigenère, kuncinya satu kata dalam bahasa Indonesia, tujuh huruf.
- **Hint 3:** Kuncinya SEKOLAH. Sambungkan From Base64 lalu Vigenère Decode.

Langkah-langkah:

- Buka soal Kunci Kata di platform, lalu salin teks soal.
- Tempel teks soal di kolom Input CyberChef.
- Tambahkan operasi From Base64 ke Recipe. Output berubah menjadi AGX{yfnja_okhl_tllez_ptsh_vmdsmar}, artinya masih ada lapis Vigenère.
- Tambahkan operasi Vigenère Decode di bawah From Base64, lalu isi kolom Key dengan tebakan kuncimu. Jika hasilnya diawali ICN{, kuncinya benar.
- Salin flag, lalu submit di platform.



Gambar 4.4 Membuka Base64 lalu Vigenère dengan kata kunci

FLAG: ICN{kunci_kata_tetap_bisa_ditebak}

Cek Pemahaman

1. Kenapa Caesar cipher mudah dibongkar walaupun kuncinya tidak diketahui?
2. Apa yang membuat Vigenère lebih sulit ditebak daripada Caesar?
3. Bagaimana mengetahui awalan flag ICN{ membantu menebak kunci sebuah cipher?

4.3 Hashing

Bayangkan database sebuah situs sekolah bocor. Isinya tidak berupa password, melainkan deretan seperti 0571749e2ac330a7455809c6b0e7af90. Admin situs merasa tenang karena hash tidak bisa dibalik. Beberapa menit kemudian, password itu sudah ditemukan lewat situs pencarian hash gratis, karena passwordnya terlalu umum.

4.3.1 Konsep

Hash adalah fungsi yang mengubah data sepanjang apa pun menjadi "sidik jari" dengan panjang tetap. Hash punya tiga sifat penting.

- **Satu arah:** Dari hash, kita tidak bisa menghitung balik data aslinya.
- **Selalu sama:** Data yang sama selalu menghasilkan hash yang sama.
- **Peka perubahan:** Beda satu huruf saja, hasilnya berubah total.

```
MD5("sekolah") = fef4cda9b13cc54433ef48d9277128d5
MD5("Sekolah") = ac47766d09939f3eba6bfa49fdab1bec
```

Jenis hash bisa dikenali dari panjangnya:

Algoritma	**Panjang (karakter hex)**	**Status**
MD5	32	Usang, jangan dipakai untuk keamanan
SHA-1	40	Usang, jangan dipakai

		untuk keamanan
SHA-256	64	Masih aman untuk cek keaslian file

Hash dipakai untuk dua hal utama. Pertama, memeriksa keaslian file: jika hash file yang kamu unduh sama dengan hash resmi dari pembuatnya, file itu tidak diubah. Kedua, menyimpan password: server hanya menyimpan hash-nya, lalu membandingkan hash saat pengguna login.

4.3.2 Hash Bisa Ditebak

Hash memang tidak bisa dibalik, tetapi bisa ditebak. Penyerang menghitung hash dari jutaan password umum yang dikumpulkan dalam daftar (wordlist), lalu mencocokkannya dengan hash yang bocor. Situs seperti CrackStation sudah menyimpan hasil tebakan ini dalam jumlah sangat besar, sehingga password umum bisa ditemukan dalam hitungan detik.

Untuk mempersulit tebakan ini, password diberi **salt**, yaitu teks acak yang berbeda untuk setiap pengguna dan digabung dengan password sebelum di-hash.

```
Tanpa salt  : hash("rahasia123")          -> sama untuk semua pengguna
Dengan salt : hash("Xq9b" + "rahasia123") -> berbeda untuk setiap pengguna
```

Dengan salt, hasil tebakan yang sudah tersimpan di situs seperti CrackStation tidak bisa dipakai lagi, dan dua pengguna dengan password yang sama tidak akan punya hash yang sama.

4.3.3 Kenapa Bisa Terjadi

```
// daftar.php (TIDAK aman)
$hash = md5($_POST['password']);
simpanUser($_POST['username'], $hash);
```

Ada tiga masalah. MD5 sangat cepat dihitung, sehingga jutaan tebakan bisa dicoba per detik. Password lemah seperti password123 sudah ada di semua wordlist. Tanpa salt, satu password yang terbongkar ikut membongkar semua akun lain yang memakai password yang sama.

4.3.4 Cara Mencegah

- Gunakan fungsi khusus password seperti bcrypt atau Argon2. Di PHP cukup pakai password_hash() dan password_verify().
- Fungsi tersebut otomatis menambahkan salt, sehingga password yang sama menghasilkan hash yang berbeda.
- Wajibkan password yang panjang dan tidak umum.

```
// daftar.php (versi aman)
$hash = password_hash($_POST['password'], PASSWORD_DEFAULT);

// login.php
if (password_verify($_POST['password'], $user['hash'])) { loginBerhasil(); }
```

Hands-On 9: Hashing

Pada sesi hands-on ini, peserta akan berperan sebagai penyerang yang mendapatkan hash password dari database yang bocor, lalu menebak password aslinya.

Part 1: Password Bocor

Database situs latihan bocor. Hash MD5 milik akun admin adalah 0571749e2ac330a7455809c6b0e7af90. Temukan passwordnya. Flag berformat ICN{password_admin}.

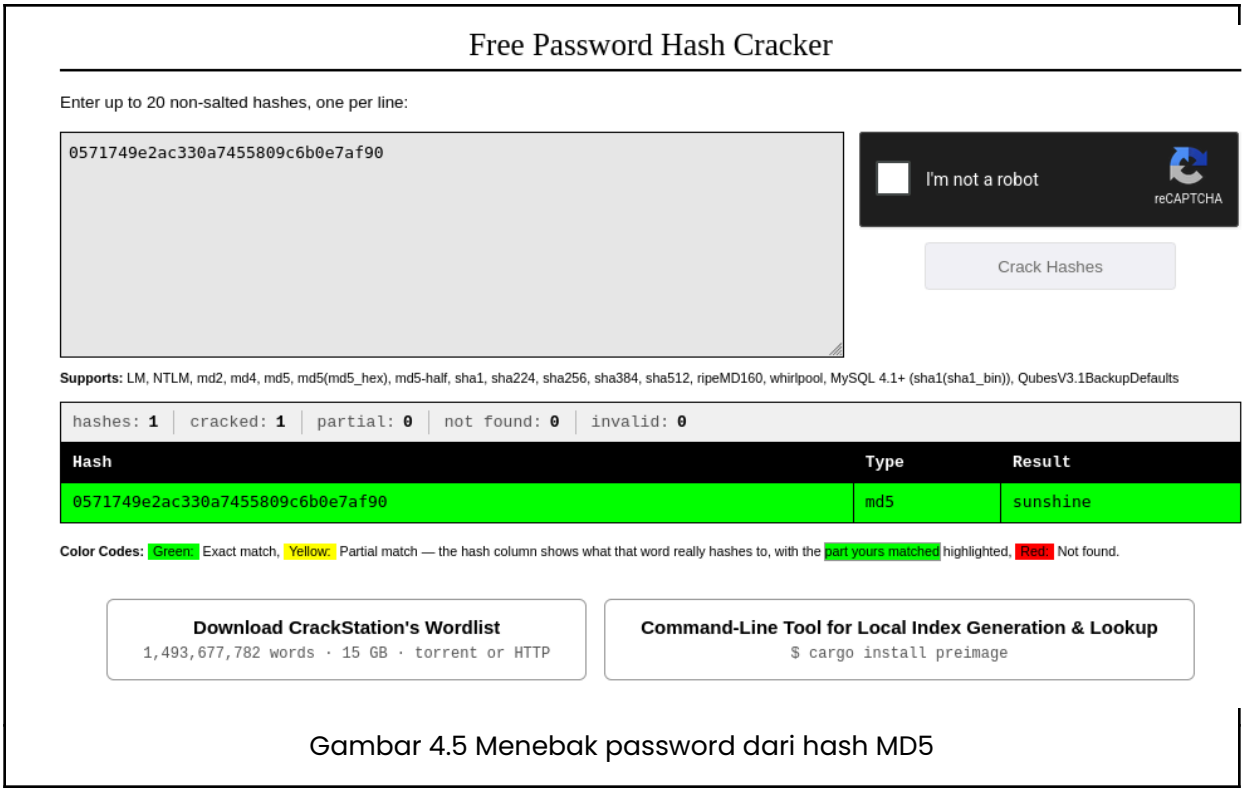
Petunjuk (hint):

- **Hint 1:** Panjang hash 32 karakter, berarti MD5.

- **Hint 2:** Hash tidak bisa dibalik, tetapi password umum sudah pernah ditebak orang lain.
- **Hint 3:** Tempel hash di situs CrackStation (https://crackstation.net).

Langkah-langkah:

- Buka soal Password Bocor di platform, lalu salin hash-nya.
- Buka CrackStation, lalu tempel hash di kolom yang tersedia.
- Klik Crack Hashes. Kolom Type menunjukkan jenis hash (md5), dan kolom Result menampilkan password aslinya.
- Masukkan password itu ke format flag, lalu submit di platform.



Gambar 4.5 Menebak password dari hash MD5

FLAG: ICN{sunshine}

Cek Pemahaman

1. Jika hash tidak bisa dibalik, kenapa password admin tetap bisa ditemukan dari hash-nya?

2. Apa fungsi salt, dan kenapa salt membuat CrackStation tidak bisa dipakai?
3. Kenapa MD5 tidak disarankan untuk menyimpan password?

Lampiran

Cheat Sheet

Ringkasan alat dan operasi yang dipakai pada Hands-On. Gunakan hanya pada platform latihan.

Teknik	**Alat atau operasi**	**Dipakai di**
Caesar tanpa kunci	CyberChef: ROT13 Brute Force + Crib ICN	Hands-On 8 Part 1
Caesar dengan kunci	CyberChef: ROT13 (atur Amount)	Hands-On 8 Part 1
Vigenère	CyberChef: From Base64 → Vigenère Decode + Key	Hands-On 8 Part 2
Menebak password dari hash	CrackStation	Hands-On 9 Part 1

Belajar Lanjutan

Untuk berlatih lebih jauh, kamu bisa mencoba CryptoHack, picoCTF (kategori Cryptography), dan dCode.fr untuk mengenal lebih banyak cipher klasik.

5. Reverse Engineering

Setiap aplikasi yang kita pakai, mulai dari game sampai aplikasi absensi, awalnya ditulis sebagai kode yang bisa dibaca manusia. Sebelum dibagikan, kode itu diubah

menjadi file program yang hanya dimengerti komputer. Banyak orang mengira isi file program tidak bisa diintip. Padahal, teks yang ditulis programmer, termasuk password, ikut tersimpan di dalamnya.

Modul ini membahas dasar Reverse Engineering, salah satu kategori dalam Capture The Flag (CTF). Kamu akan mencari flag yang tersembunyi di dalam sebuah program hanya dengan dua alat: `strings` dan CyberChef, tanpa perlu membaca kode mesin.

5.1 Pengantar Reverse Engineering

Reverse Engineering adalah kategori CTF yang berfokus pada membongkar program untuk memahami cara kerjanya, tanpa melihat kode aslinya. Soalnya biasanya berupa sebuah file program. Flag tersembunyi di dalam program itu, misalnya sebagai password yang dicek oleh program.

5.1.1 Dari Kode Menjadi Program

Programmer menulis kode sumber (source code), misalnya dalam bahasa C. Kode itu lalu diubah oleh compiler menjadi file program (binary) yang bisa dijalankan komputer.

```
gcc gerbang.c -o gerbang     # gerbang.c = kode sumber, gerbang = program
```

Isi binary sebagian besar berupa instruksi mesin yang sulit dibaca. Namun, semua teks di dalam kode, seperti pesan, nama fungsi, dan password, tetap disimpan apa adanya di dalam file.

5.1.2 Alat yang Dipakai: strings dan CyberChef

- **strings:** Mencari semua deretan karakter yang bisa dibaca di dalam sebuah file, minimal 4 karakter berturut-turut. Di Linux atau WSL cukup ketik `strings namafile`.

- **CyberChef:** Situs gratis untuk mengolah data (`https://gchq.github.io/CyberChef/`). CyberChef juga punya operasi Strings, sehingga bisa dipakai di Windows tanpa memasang apa pun. Klik ikon Open file as input, pilih file program, lalu tambahkan operasi Strings ke Recipe.

```
$ strings gerbang
=== Gerbang SMA Forge ===
Masukkan password gerbang:
Password salah. Satpam curiga.
```

5.2 Rahasia di Dalam Program

Bayangkan aplikasi absensi sekolah yang menyimpan password admin langsung di dalam kodenya. Programmer merasa aman karena kodenya tidak dibagikan, hanya file programnya. Padahal siapa pun yang punya file program itu bisa menjalankan `strings` dan menemukan password tersebut dalam hitungan detik.

5.2.1 Konsep

Menyimpan password atau kunci langsung di dalam program disebut hardcoded secret. Agar tidak terlihat oleh `strings`, programmer kadang menyamarkannya, misalnya dengan XOR: setiap huruf dicampur dengan satu angka kunci sehingga berubah menjadi huruf lain yang tidak bermakna.

Masalahnya, program tetap harus bisa mengecek password, jadi teks yang disamarkan dan kuncinya sama-sama ada di dalam program. XOR juga bisa dibalik dengan XOR yang sama. Jika kunci hanya satu byte, ada 256 kemungkinan saja, dan semuanya bisa dicoba. Karena flag selalu diawali `ICN{`, kunci yang benar adalah kunci yang menghasilkan awalan itu.

5.2.2 Kenapa Bisa Terjadi

```
// gerbang.c (TIDAK aman)
const unsigned char enc[] = {0x63, 0x69, 0x64, 0x51, ...};   // password
yang di-XOR
```

```
for (size_t i = 0; i < sizeof(enc); i++) {
    if ((input[i] ^ 0x2A) != enc[i])   // kunci XOR ditulis di kode
        return 0;
}
```

Password yang sudah disamarkan (`enc`) dan kuncinya (`0x2A`) sama-sama tersimpan di dalam program. Siapa pun yang punya file program bisa mengambil keduanya, lalu membalik XOR untuk mendapatkan password asli.

5.2.3 Cara Mencegah

- Jangan menyimpan password, kunci API, atau data rahasia lain di dalam program yang dibagikan ke pengguna.
- Lakukan pengecekan password di server, sehingga rahasianya tidak pernah ikut terkirim ke komputer pengguna.
- Jika program harus mengecek password secara lokal, simpan hash-nya saja dengan fungsi khusus seperti bcrypt, bukan teks yang hanya disamarkan.

Hands-On 10: Reverse Engineering

Pada hands-on ini, peserta akan mencari password yang tersembunyi di dalam sebuah program. Peserta tidak perlu membaca kode mesin. Cukup gunakan `strings` untuk menemukan teks yang mencurigakan, lalu CyberChef untuk membalik penyamarannya.

Soal: Kunci Gerbang

Satpam SMA Forge mengunci gerbang dengan program kecil bernama `gerbang`. Passwordnya tidak pernah ditulis di mana pun, tetapi program tetap bisa mengeceknya. Berarti jawabannya ada di dalam program itu sendiri. Password yang benar adalah flag-nya. File soal (`gerbang`) bisa diunduh di platform.

Petunjuk (Hint)

- **Hint 1:** Coba `strings gerbang`. Flag tidak muncul utuh, tetapi ada satu baris aneh yang mencurigakan.

- **Hint 2:** Baris itu adalah password yang di-XOR dengan kunci satu byte.
- **Hint 3:** Gunakan operasi XOR Brute Force di CyberChef dengan Crib `ICN`.

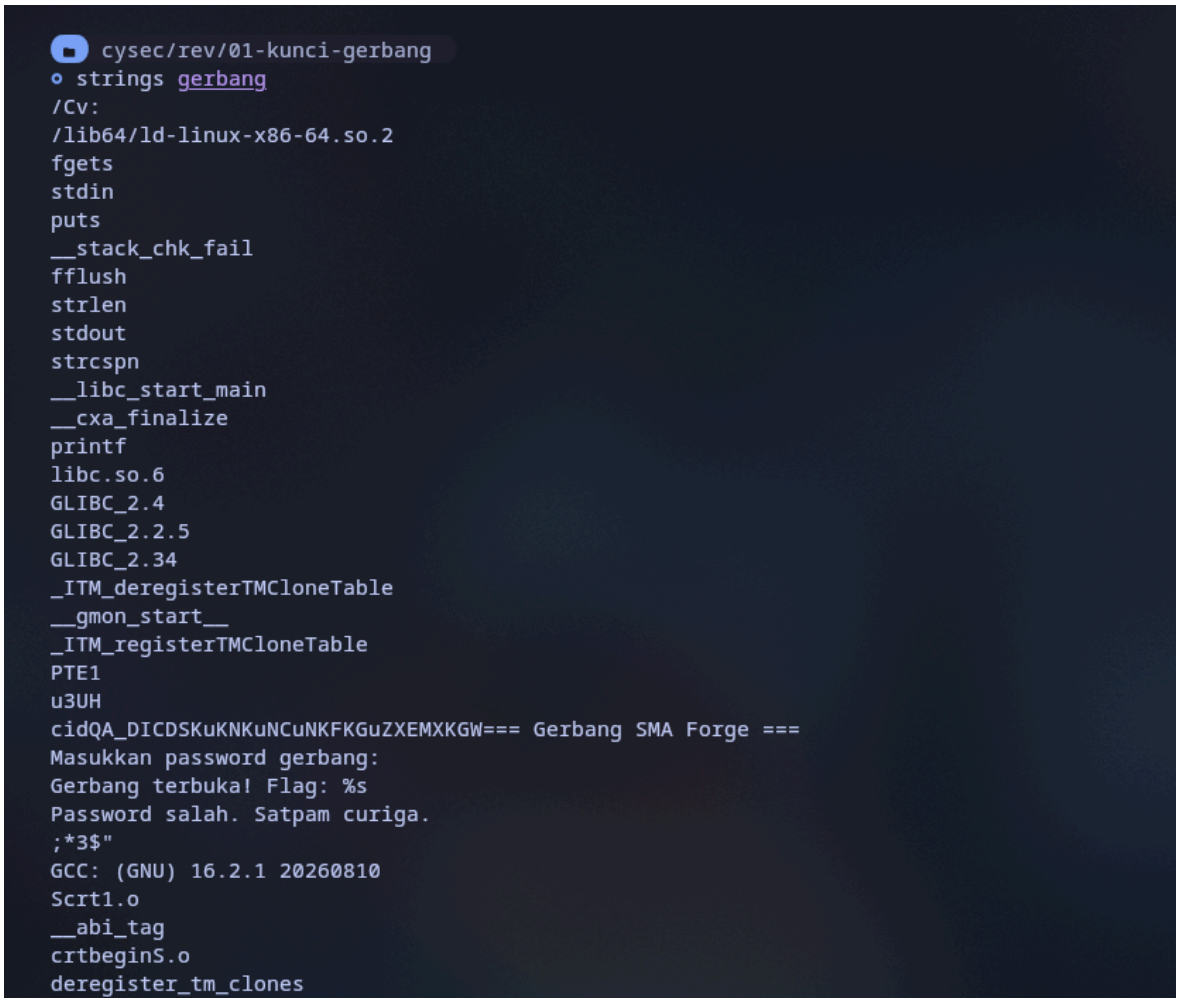
Langkah Pengerjaan

Langkah 1: Mencari Teks dengan strings

Unduh file `gerbang` dari platform. Di Linux atau WSL, jalankan perintah berikut. Di Windows, buka CyberChef, klik ikon Open file as input, pilih file `gerbang`, lalu tambahkan operasi Strings.

```
$ strings gerbang
...
cidQA_DICDSKuKNKuNCuNKFKGuZXEMXKGW=== Gerbang SMA Forge ===
Masukkan password gerbang:
Gerbang terbuka! Flag: %s
Password salah. Satpam curiga.
...
```

Sebagian besar hasilnya adalah nama fungsi dan pesan program. Perhatikan satu baris yang diawali huruf acak `cidQA_DICDSK...`, tepat menempel di depan judul program.



Gambar 5.1 Mencari teks di dalam program dengan strings

Langkah 2: Mengenali Teks yang Disamarkan

Huruf acak itu bukan bagian dari judul. Program menyimpan password yang di-XOR tanpa penanda akhir, sehingga `strings` menyambungnya dengan teks berikutnya. Ambil hanya bagian sebelum `===`:

```
cidQA_DICDSKuKNKuNCuNKFKGuZXEMXKGW
```

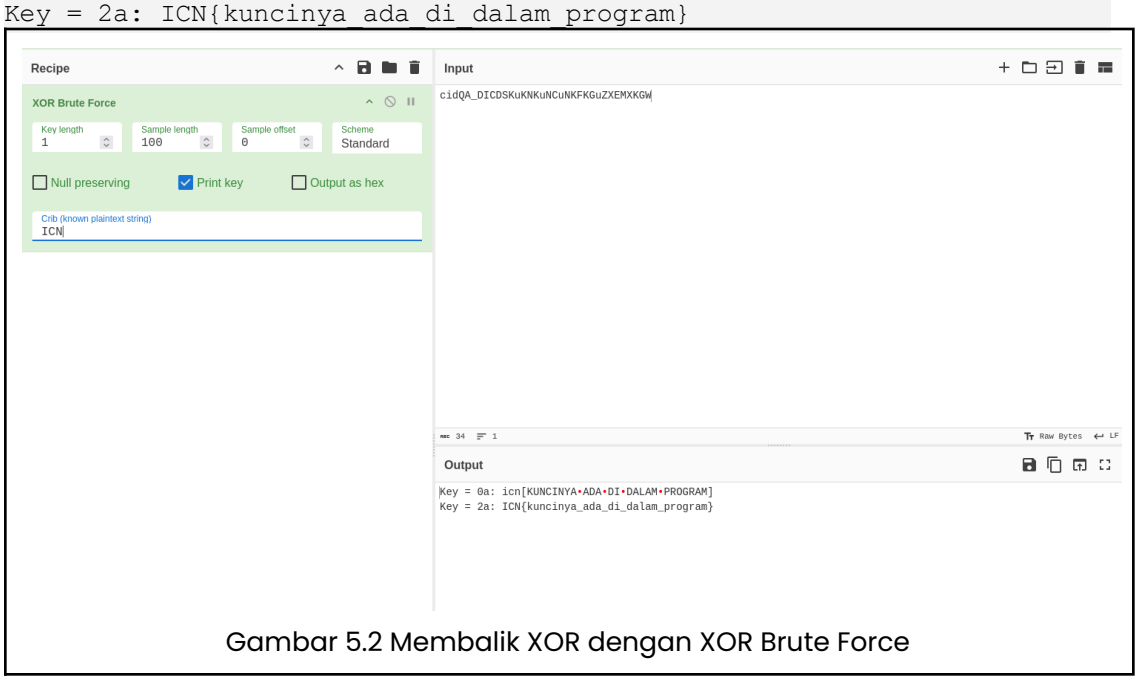
Panjangnya 34 karakter, sama seperti panjang sebuah flag. Ini kandidat kuat password yang disamarkan.

Langkah 3: Membalik XOR di CyberChef

- Buka CyberChef, lalu tempel teks dari Langkah 2 di kolom Input.

- Tambahkan operasi XOR Brute Force ke Recipe. Biarkan Key length bernilai 1.
- Isi kolom Crib (known plaintext string) dengan `ICN`. Output hanya menampilkan kunci yang menghasilkan awalan `ICN`.
- Output menunjukkan kunci `2a` beserta password aslinya.

```
Key = 2a: ICN{kuncinya_ada_di_dalam_program}
```



Gambar 5.2 Membalik XOR dengan XOR Brute Force

Langkah 4: Membuka Gerbang

Jika bisa menjalankan program di Linux, masukkan flag sebagai password untuk memastikan jawabannya benar. Langkah ini tidak wajib.

```
$ ./gerbang
=== Gerbang SMA Forge ===
Masukkan password gerbang: ICN{kuncinya_ada_di_dalam_program}
Gerbang terbuka! Flag: ICN{kuncinya_ada_di_dalam_program}
```

FLAG: ICN{kuncinya_ada_di_dalam_program}

Cek Pemahaman

- Kenapa password yang ditulis di dalam kode program bisa ditemukan dengan strings?
- Kenapa menyamarkan password dengan XOR tidak membuatnya aman?

- Di mana sebaiknya pengecekan password dilakukan agar rahasianya tidak bocor?

6. Binary Exploitation

Aplikasi seperti game, pemutar musik, atau server web ditulis dengan bahasa pemrograman, lalu diubah menjadi file program siap jalan yang disebut binary. Jika pembuatnya lupa membatasi data yang masuk, input dari pengguna bisa menimpa bagian memori yang seharusnya tidak boleh disentuh, dan program pun berperilaku di luar rencana.

Modul ini membahas dasar Binary Exploitation, salah satu kategori dalam Capture The Flag (CTF). Fokusnya adalah buffer overflow, kesalahan paling klasik pada program berbahasa C, sampai peserta bisa membuat sebuah program crash untuk mendapatkan flag.

6.1 Pengantar Binary Exploitation

Binary Exploitation, yang sering disebut pwn, adalah kategori CTF yang berfokus pada mencari kesalahan dalam program yang sudah dikompilasi, lalu memanfaatkannya agar program berperilaku di luar rencana pembuatnya. Pada soal CTF, peserta biasanya mendapat file program atau kode sumbernya, ditambah alamat server tempat program itu berjalan.

6.1.1 Memori dan Stack

Saat program berjalan, datanya disimpan di memori. Variabel lokal di dalam sebuah fungsi disimpan di bagian memori yang disebut stack. Di stack, variabel-variabel itu disusun berdampingan, dan di dekatnya tersimpan alamat kembali (return address), yaitu catatan ke mana program harus melanjutkan setelah fungsi selesai.

```
[ nama (16 byte)  ]  <- input pengguna ditulis di sini
[ data lain       ]
[ alamat kembali  ]  <- ke mana program lanjut setelah fungsi selesai
```

Buffer adalah tempat penampung data dengan ukuran tetap, misalnya `char nama[16]` yang hanya muat 16 byte. Satu huruf memakai satu byte, dan string di bahasa C selalu diakhiri satu byte penutup, jadi buffer ini hanya muat 15 huruf.

6.1.2 Segmentation Fault

Setiap program hanya boleh mengakses memori miliknya sendiri. Jika program mencoba membaca atau melompat ke alamat yang tidak valid, sistem operasi langsung menghentikannya dengan pesan Segmentation fault. Bagi pengguna biasa, ini terlihat seperti program crash. Bagi pemain CTF, segmentation fault adalah tanda bahwa input yang dikirim berhasil merusak sesuatu di memori.

6.1.3 Alat yang Dipakai: netcat

Soal binary exploitation biasanya berjalan di server dan diakses lewat netcat (`nc`). Setelah tersambung, apa pun yang diketik dikirim ke program di server, dan keluaran program tampil di terminal.

```
nc <alamat-server> <port>
```

Untuk mengirim input yang panjang tanpa mengetik satu per satu, gabungkan netcat dengan Python. Perintah berikut mengirim 100 huruf A sekaligus:

```
python3 -c "print('A' * 100)" | nc <alamat-server> <port>
```

6.2 Buffer Overflow

Bayangkan gelas 200 ml diisi air satu liter. Air yang tidak muat akan tumpah dan membasahi barang di sekitarnya. Buffer overflow terjadi dengan cara yang sama: data yang lebih panjang dari ukuran buffer meluber dan menimpa data lain di sebelahnya.

6.2.1 Konsep

Buffer overflow terjadi ketika program menyalin input ke dalam buffer tanpa memeriksa panjangnya. Kelebihan data menimpa isi stack di sebelah buffer, termasuk alamat kembali. Ketika fungsi selesai, program melompat ke alamat yang sudah rusak, misalnya `0x4141414141414141` (41 adalah kode hex huruf A), lalu terjadi segmentation fault.

- **Input pendek (maksimal 15 huruf):** Muat di dalam buffer, program berjalan normal.
- **Input panjang (16 huruf atau lebih):** Meluber ke luar buffer, menimpa data di sebelahnya termasuk alamat kembali, lalu program crash.

Pada program sungguhan, penyerang tidak berhenti di crash. Alamat kembali bisa diisi dengan alamat pilihan penyerang sehingga program menjalankan kode lain. Teknik lanjutan ini di luar cakupan modul dasar ini.

6.2.2 Kenapa Bisa Terjadi

```
// bukutamu.c (TIDAK aman)
void tulis_buku_tamu(char *input) {
    char nama[16];
    strcpy(nama, input);   // tidak mengecek panjang input
}
```

Fungsi `strcpy` menyalin input sampai bertemu akhir string, berapa pun panjangnya. Bahasa C tidak memeriksa batas buffer secara otomatis, sehingga tanggung jawab itu ada pada programmer. Fungsi lain dengan masalah serupa adalah `gets`, `scanf("%s")`, dan `strcat`.

6.2.3 Cara Mencegah

- Gunakan fungsi yang membatasi panjang, seperti `fgets` dan `snprintf`, sebagai pengganti `gets` dan `strcpy`.

- Periksa panjang input sebelum disalin, dan tolak input yang melebihi ukuran buffer.
- Aktifkan proteksi dari compiler dan sistem operasi, seperti stack canary, ASLR, dan NX. Proteksi ini tidak menghapus bug, tetapi membuatnya lebih sulit dimanfaatkan.
- Jika memungkinkan, gunakan bahasa yang memeriksa batas memori secara otomatis, seperti Python, Java, atau Rust.

```
// bukutamu.c (versi aman)
char nama[16];
snprintf(nama, sizeof(nama), "%s", input);   // sisa input dipotong
```

Latihan Extra: Buffer Overflow

Pada hands-on ini, peserta akan membuat sebuah program crash dengan mengirim input yang lebih panjang dari ukuran buffer. Programnya adalah buku tamu sederhana yang berjalan di server dan diakses lewat netcat.

Pembuat soal sudah memasang penanda: begitu program mengalami segmentation fault, flag langsung ditampilkan. Tugas peserta adalah membaca kode sumbernya, menemukan buffer yang bisa diluberkan, lalu membuat program crash.

Soal: Buku Tamu ICN Lab

ICN Lab membuat buku tamu digital. Program meminta nama pengunjung, lalu menampilkan ucapan terima kasih. Kode sumber program (`bukutamu.c`) bisa diunduh di platform. Buat program ini crash untuk mendapatkan flag.

```
nc <alamat-server> 9002
```

Petunjuk (Hint)

- **Hint 1:** Perhatikan ukuran variabel `nama` di fungsi `tulis_buku_tamu`.
- **Hint 2:** `strcpy` tidak peduli ukuran buffer. Apa yang terjadi jika nama yang dikirim lebih dari 15 huruf?
- **Hint 3:** Kirim 100 huruf A sebagai nama.

Langkah Pengerjaan

Langkah 1: Membaca Kode Sumber

Buka `bukutamu.c` dan cari bagian yang menerima input. Ada tiga hal yang perlu diperhatikan:

- Fungsi `main` membaca input sampai 255 karakter dengan `fgets`, lalu meneruskannya ke `tulis_buku_tamu`.
- Fungsi `tulis_buku_tamu` menyalin input ke variabel `nama` yang hanya berukuran 16 byte dengan `strcpy`, tanpa mengecek panjangnya.
- Baris `signal(SIGSEGV, kalau_crash)` membuat fungsi `kalau_crash` dipanggil saat terjadi segmentation fault, dan fungsi itulah yang mencetak flag.

Artinya, input sampai 255 karakter bisa masuk ke buffer yang hanya muat 15 huruf.

```c
void tulis_buku_tamu(char *input) {
    char nama[16];          // hanya muat 15 karakter + 1 penutup string
    strcpy(nama, input);    // menyalin tanpa mengecek panjang input
    printf("Terima kasih sudah berkunjung, %s!\n", nama);
}
```

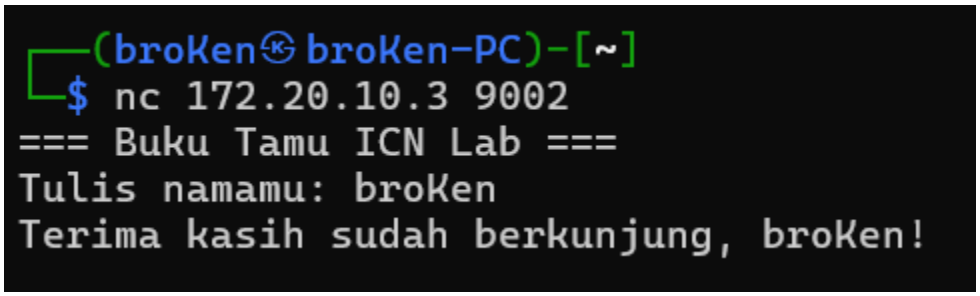
Gambar 6.1 Bagian kode yang rentan pada bukutamu.c

Langkah 2: Mencoba Input Normal

Sambungkan ke server dengan netcat, lalu ketik nama biasa, misalnya Budi.

```
$ nc <alamat-server> 9002
=== Buku Tamu ICN Lab ===
Tulis namamu: Budi
Terima kasih sudah berkunjung, Budi!
```

Program berjalan normal karena nama Budi muat di dalam buffer.



Gambar 6.2 Program berjalan normal dengan input pendek

Langkah 3: Meluberkan Buffer

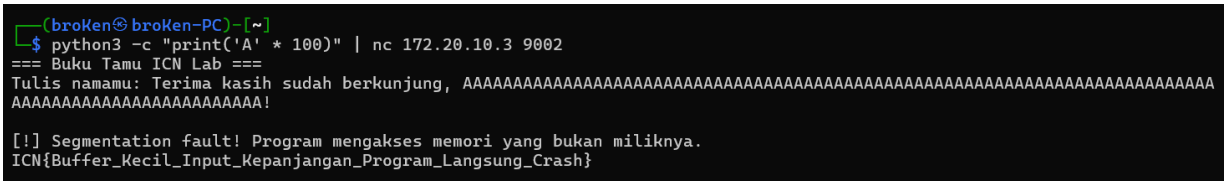
Sekarang kirim nama yang jauh lebih panjang dari 15 huruf. Cara termudah adalah membuat 100 huruf A dengan Python:

```
python3 -c "print('A' * 100)" | nc <alamat-server> 9002
```

Huruf A yang meluber menimpa alamat kembali fungsi `tulis_buku_tamu`. Saat fungsi selesai, program melompat ke alamat `0x4141414141414141` yang tidak valid, terjadi segmentation fault, dan flag muncul:

```
Tulis namamu: Terima kasih sudah berkunjung, AAAA...AAAA!
[!] Segmentation fault! Program mengakses memori yang bukan miliknya.
ICN{Buffer_Kecil_Input_Kepanjangan_Program_Langsung_Crash}
```

Mengetik huruf A secara manual lewat netcat juga berhasil, asalkan lebih dari 15 huruf.


(broKen㉿broKen-PC)-[~]
$ python3 -c "print('A' * 100)" | nc 172.20.10.3 9002
=== Buku Tamu ICN Lab ===
Tulis namamu: Terima kasih sudah berkunjung, AAAA

Gambar 6.3 Program crash dan menampilkan flag

FLAG: ICN{Buffer_Kecil_Input_Kepanjangan_Program_Langsung_Crash}

Cek Pemahaman

- Kenapa nama Budi tidak membuat program crash, sedangkan 100 huruf A membuatnya crash?
- Apa itu alamat kembali (return address), dan apa yang terjadi jika nilainya tertimpa input pengguna?
- Bagaimana mengganti `strcpy` dengan `snprintf` mencegah buffer overflow pada program buku tamu?